

Università degli studi di Milano

Corso di Laurea Magistrale in Sicurezza Informatica

Sicurezza nelle Architetture Data Intensive

DermaTriage

Docente: Ernesto Damiani

Anno: I° Anno

Trimestre: III° Trimestre

Anno Accademico: 2025/2026

Componenti del gruppo:

Giuseppe Corasaniti - Matricola 84237A

Giuseppe Favata - Matricola 84231A

Matteo Toso - Matricola 85540A

Indice

1	Architettura del sistema	3
1.1	Ambito del sistema e integrazione con B4	3
1.2	Pipeline di elaborazione e decisione clinica	4
1.2.1	Stage 1 - Classificazione dell'urgenza con EfficientNet-B4	4
1.2.2	Stage 2 - Descrizione clinica con Qwen2-VL	4
1.2.3	Stage 3 - Recupero di casi clinici simili	5
1.2.4	Stage 4 - Sintesi clinica con BioMistral	5
1.2.5	Adaptation layer e assegnazione della priorità	5
1.3	Componenti persistenti, modelli e dipendenze esterne	6
1.3.1	Dataset e persistenza dei dati	6
1.3.2	Modelli e checkpoint	7
1.3.3	Ambiente di esecuzione e servizi esterni	7
1.4	Aggiornamento e validazione del sistema	7
1.4.1	Validazione clinica e raccolta del feedback	7
1.4.2	Evoluzione dei prompt	8
1.4.3	Retraining del classificatore EfficientNet-B4	8
1.4.4	Validazione tecnica e gestione delle versioni	8
2	Identificazione degli asset	10
2.1	Dati clinici e input	10
2.2	Inferenze e risultati della pipeline	11
2.3	Dataset e persistenza	11
2.4	Feedback e aggiornamento	12
2.5	Modelli e artefatti AI	13
2.6	Logica decisionale	14
2.7	Servizi applicativi e configurazione	15
3	Failure Mode and Effects Analysis	16
3.1	A01 - Immagine dermatologica	16
3.1.1	Funzioni e prerequisiti	16
3.1.2	Failure mode	17
3.2	A13 - Feedback clinico validato	18
3.2.1	Funzioni e prerequisiti	18
3.2.2	Failure mode	19
3.3	A16 - Modello EfficientNet-B4	19
3.3.1	Funzioni e prerequisiti	20
3.3.2	Failure mode	20
3.4	A20 - Regole dell'Adaptation Layer	21

3.4.1	Funzioni e prerequisiti	21
3.4.2	Failure mode	22
3.5	A21 - Piattaforma B4	23
3.5.1	Funzioni e prerequisiti	23
3.5.2	Failure mode	23
4	Security Properties e Threat Mapping	25
4.1	Proprietà di sicurezza CIA ³ -R	25
4.2	Mapping STRIDE-AI	25
4.2.1	A01 - Immagine dermatologica	26
4.2.2	A13 - Feedback clinico validato	26
4.2.3	A16 - Modello EfficientNet-B4	27
4.2.4	A20 - Regole dell'Adaptation Layer	28
4.2.5	A21 - Piattaforma B4	28
4.3	Mapping OWASP AI e Agentic AI	29
4.3.1	Applicabilità dei rischi Agentic AI	31
5	Risk Assessment	32
5.1	Valutazione RPN dei failure mode	32
5.2	Valutazione DREAD delle minacce	33
5.3	Prioritizzazione finale	35
6	Threat Scenarios e Threat Trees	37
6.1	FM01.4 - Manipolazione intenzionale dell'immagine	37
6.1.1	Threat tree	37
6.2	FM13.1 - Contenuti avversariali nel feedback clinico	38
6.2.1	Threat tree	39
6.3	FM20.3 - Alterazione delle regole dell'Adaptation Layer	40
6.3.1	Threat tree	40
6.4	FM21.5 - Esposizione non autorizzata dei dati clinici	41
6.4.1	Threat tree	41
7	Mitigation e Residual Risk	43
7.1	FM01.4 - Manipolazione intenzionale dell'immagine	43
7.2	FM13.1 - Contenuti avversariali nel feedback clinico	44
7.3	FM20.3 - Alterazione delle regole dell'Adaptation Layer	46
7.4	FM21.5 - Esposizione non autorizzata dei dati clinici	47
7.5	Valutazione del rischio residuo	48
7.6	Assunzioni, limiti e controlli non pienamente verificabili	50

1. Architettura del sistema

DermaTriage è un sistema di triage dermatologico assistito da intelligenza artificiale, sviluppato nell'ambito del progetto AI vs Cancer. Il sistema elabora immagini di lesioni cutanee inviate dai pazienti insieme a informazioni cliniche e demografiche, con l'obiettivo di stimare il livello di urgenza del caso e assegnare una priorità clinica compresa tra P1 e P4.

DermaTriage è integrato con la piattaforma B4 (Social Things), che rappresenta il punto di interazione con il paziente e mette a disposizione le API utilizzate per lo scambio dei dati relativi ai consulti, ai documenti caricati, ai risultati diagnostici e alle validazioni mediche. L'elaborazione diagnostica viene invece eseguita dal servizio DermaTriage, che espone un'applicazione FastAPI e implementa una pipeline di intelligenza artificiale composta da quattro stadi, seguita da un adaptation layer responsabile della conversione del risultato nella scala clinica P1-P4.

1.1. Ambito del sistema e integrazione con B4

L'interazione con il paziente avviene attraverso la piattaforma B4, che raccoglie le informazioni necessarie per avviare il processo di triage. Nel flusso principale vengono acquisiti un'immagine della lesione cutanea, l'età del paziente, il sesso e la localizzazione anatomica della lesione. A questi dati possono aggiungersi informazioni relative alla sintomatologia, tra cui prurito, sanguinamento, crescita della lesione, cambiamenti morfologici e dolore.

Una volta raccolti i dati, DermaTriage accede alle informazioni associate alla richiesta attraverso le API messe a disposizione da B4. Il servizio può recuperare i consulti disponibili, individuare i documenti associati e scaricare l'immagine dermatologica necessaria all'elaborazione. Al termine della pipeline diagnostica, il risultato viene restituito a B4 e associato alla relativa richiesta di triage. La successiva validazione da parte del personale medico permette di ottenere un riscontro sull'esito prodotto dal sistema. Tali informazioni possono essere recuperate da DermaTriage e alimentare i meccanismi di aggiornamento del sistema, che comprendono l'evoluzione dei prompt e il retraining del classificatore EfficientNet-B4.

La comunicazione tra DermaTriage e B4 avviene tramite API REST protette da autenticazione. L'accesso ai servizi B4 utilizza un Bearer JWT ottenuto tramite l'endpoint `/api/v1/auth/token`; la gestione del token è affidata al componente `B4Auth`, che ne esegue il rinnovo automatico alla scadenza. I parametri necessari all'integrazione, tra cui credenziali, API key e indirizzo del servizio B4, sono configurati mediante variabili d'ambiente dedicate.

Il flusso integrato viene avviato attraverso l'endpoint `POST /diagnose`, al quale viene fornito un `consulto_id` come riferimento alla richiesta da elaborare. L'accesso a questo

endpoint richiede l'header `X-API-Key`, utilizzato anche per le funzionalità amministrative relative alla validazione delle diagnosi, alla gestione dei prompt e al retraining dei modelli.

Accanto al percorso integrato con B4, DermaTriage espone anche `POST /analyze`, che permette di avviare direttamente la pipeline fornendo un'immagine JPEG o PNG insieme a età, sesso e localizzazione. Questo secondo percorso consente quindi di utilizzare il motore diagnostico anche senza partire da una richiesta già presente sulla piattaforma B4.

Dal punto di vista architetturale, B4 e DermaTriage mantengono ruoli distinti. B4 gestisce l'interazione iniziale con il paziente e rende disponibili i dati necessari al processo di triage, mentre DermaTriage esegue l'elaborazione diagnostica e gestisce i meccanismi di aggiornamento dei modelli. L'integrazione tra i due sistemi è quindi bidirezionale e accompagna il caso clinico dalla fase di acquisizione fino alla restituzione e alla successiva validazione del risultato.

1.2. Pipeline di elaborazione e decisione clinica

L'elaborazione interna di DermaTriage si articola in quattro stadi che contribuiscono alla costruzione del risultato finale. L'architettura combina un classificatore visuale, un modello vision-language, un sistema di retrieval basato su casi clinici e un modello linguistico specializzato in ambito medico. Il risultato ottenuto viene successivamente trasformato nella priorità clinica utilizzata dal sistema.

1.2.1. Stage 1 - Classificazione dell'urgenza con EfficientNet-B4

Il primo stadio esegue una classificazione dell'immagine della lesione attraverso EfficientNet-B4, un modello convoluzionale sottoposto a fine-tuning per distinguere tre livelli di urgenza denominati `HIGH`, `MEDIUM` e `LOW`. L'immagine viene elaborata come input RGB di dimensione 380×380 pixel e il modello restituisce, oltre alla classe prevista, un valore di confidenza e le probabilità associate alle tre classi.

Per aumentare la sensibilità verso i casi considerati più urgenti, la classificazione `HIGH` utilizza una soglia operativa pari a 0.25. Questa prima valutazione non determina direttamente la priorità finale P1-P4, ma costituisce una delle informazioni utilizzate nelle fasi successive della pipeline.

1.2.2. Stage 2 - Descrizione clinica con Qwen2-VL

In parallelo alla classificazione dell'urgenza, l'immagine viene analizzata da Qwen2-VL-7B-Instruct. Il modello interpreta visivamente la lesione e genera una descrizione clinica testuale organizzata in cinque aspetti principali, relativi alla forma, ai bordi, al colore, alla texture e alla presenza di caratteristiche considerate sospette.

Questo passaggio trasforma quindi il contenuto visuale in una rappresentazione testuale strutturata. La descrizione prodotta non rappresenta ancora una decisione diagnostica,

ma viene utilizzata come query per la fase di ricerca dei casi clinici simili.

1.2.3. Stage 3 - Recupero di casi clinici simili

Il terzo stadio introduce un meccanismo di Retrieval-Augmented Generation basato su ChromaDB. La descrizione generata da Qwen2-VL viene convertita in una rappresentazione vettoriale mediante il modello `all-MiniLM-L6-v2` e confrontata con le descrizioni presenti nell'indice vettoriale.

La ricerca utilizza la similarità coseno e seleziona i cinque casi più vicini alla descrizione della lesione corrente. Per ciascun risultato vengono recuperate informazioni quali l'identificativo anonimizzato del paziente, la diagnosi associata, il livello di urgenza e il punteggio di similarità. In questo modo la pipeline affianca alla valutazione dell'immagine un riferimento a casi clinici precedenti con caratteristiche semanticamente simili.

1.2.4. Stage 4 - Sintesi clinica con BioMistral

Le informazioni prodotte nei primi tre stadi vengono successivamente aggregate e fornite a BioMistral-7B insieme ai dati relativi alla sintomatologia del paziente. Il modello riceve quindi la classificazione prodotta da EfficientNet-B4, la descrizione visuale generata da Qwen2-VL e i casi recuperati dal sistema RAG, disponendo di un contesto più ampio rispetto a quello disponibile nei singoli stadi precedenti.

BioMistral produce una risposta strutturata contenente il livello finale di urgenza, la relativa confidenza, una motivazione della decisione, l'azione raccomandata e una possibile patologia associata. Questo risultato rappresenta l'uscita della componente di inferenza vera e propria e viene successivamente elaborato dall'adaptation layer.

1.2.5. Adaptation layer e assegnazione della priorità

L'adaptation layer converte il livello di urgenza prodotto dalla pipeline nella scala P1-P4 utilizzata per il triage. La funzione `map_urgency_to_p_scale()` applica una serie di regole che tengono conto sia della classe di urgenza sia, per i casi `HIGH`, del livello di confidenza ottenuto.

Un risultato `HIGH` con confidenza superiore a 0.85 viene associato alla priorità P1, con un tempo previsto di presa in carico pari a 24 ore. Gli altri casi `HIGH` vengono assegnati a P2 con un intervallo di 48 ore, mentre le classi `MEDIUM` e `LOW` vengono convertite rispettivamente in P3, con 72 ore, e P4, con 7 giorni.

L'output finale comprende quindi la priorità P1-P4, il livello di confidenza, lo specialista indicato e il relativo SLA. L'adaptation layer separa in questo modo il risultato interno prodotto dai modelli dalla rappresentazione utilizzata per il triage clinico.

La Figura 1 riassume i principali componenti dell'architettura e il percorso seguito dalle informazioni durante l'elaborazione di una richiesta di triage.

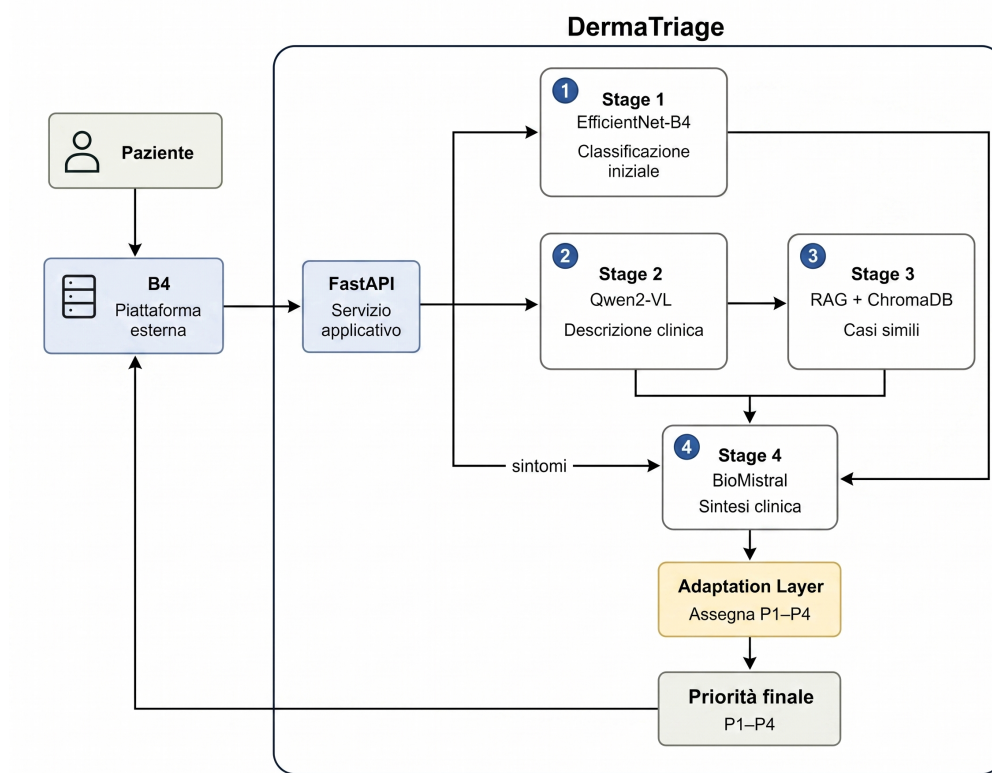


Figura 1: Architettura logica di DermaTriage e flusso principale di elaborazione

1.3. Componenti persistenti, modelli e dipendenze esterne

Oltre ai componenti coinvolti direttamente nel flusso di inferenza, DermaTriage utilizza diverse risorse persistenti per conservare i dati necessari al funzionamento della pipeline, i modelli e le informazioni prodotte durante l'esecuzione. Una parte di queste risorse viene utilizzata durante l'elaborazione delle richieste, mentre altre supportano la gestione e l'aggiornamento del sistema.

1.3.1. Dataset e persistenza dei dati

Il dataset utilizzato dal sistema RAG è conservato localmente nel file `RAG_dataset.csv` e contiene 2298 casi clinici derivati dal dataset pubblico ISIC. Le informazioni necessarie al retrieval vengono indicizzate in ChromaDB, il cui database vettoriale è mantenuto in modo persistente all'interno dell'ambiente DermaTriage.

Oltre alle risorse utilizzate dal RAG, il sistema conserva localmente le diagnosi prodotte, le correzioni effettuate durante la revisione dei risultati, le versioni dei prompt e le informazioni relative alle versioni dei modelli. Questi dati vengono utilizzati dalle funzionalità amministrative e dai meccanismi di aggiornamento del sistema.

Le immagini provenienti dalle richieste B4 vengono elaborate durante il processo di triage

senza essere aggiunte in modo permanente al dataset utilizzato dal sistema RAG. Quelle impiegate per l'addestramento sono invece conservate insieme ai relativi metadati, mentre file distinti definiscono gli insiemi impiegati nelle fasi di training, validation e test.

1.3.2. Modelli e checkpoint

I pesi del classificatore EfficientNet-B4 sono memorizzati localmente e caricati dal relativo checkpoint per l'esecuzione dell'inferenza. Il sistema mantiene inoltre i checkpoint prodotti dai successivi cicli di retraining e una copia di backup, così da supportare il versionamento del classificatore e il ripristino di una versione precedente quando necessario.

Qwen2-VL-7B-Instruct, BioMistral-7B e `all-MiniLM-L6-v2` vengono invece acquisiti tramite Hugging Face e caricati nell'ambiente di esecuzione di DermaTriage. Una volta disponibili localmente, vengono utilizzati direttamente dalla pipeline senza richiedere un servizio remoto di inferenza durante l'elaborazione dei casi clinici.

1.3.3. Ambiente di esecuzione e servizi esterni

DermaTriage è predisposto per l'esecuzione su un ambiente Linux dotato di GPU NVIDIA e supporto CUDA. L'applicazione FastAPI viene eseguita tramite Uvicorn ed espone le funzionalità necessarie all'accesso alla pipeline e alle operazioni amministrative. L'esecuzione dei modelli può avvenire anche su CPU, con tempi di elaborazione maggiori rispetto all'utilizzo dell'accelerazione GPU.

La principale interazione con un sistema esterno durante il funzionamento operativo rimane quella con B4. Attraverso le relative API, DermaTriage recupera i dati e i documenti necessari all'elaborazione, restituisce gli output diagnostici e può acquisire gli esiti clinici validati utilizzati nei processi di aggiornamento.

1.4. Aggiornamento e validazione del sistema

DermaTriage utilizza le correzioni raccolte durante la revisione dei risultati per aggiornare nel tempo alcuni componenti della pipeline. Il processo interessa sia i prompt utilizzati dai modelli generativi sia il classificatore EfficientNet-B4, attraverso due meccanismi distinti. Nel primo caso vengono aggiornati i prompt utilizzati dai modelli, mentre nel secondo vengono aggiornati i pesi del classificatore mediante un nuovo ciclo di fine-tuning.

1.4.1. Validazione clinica e raccolta del feedback

Le diagnosi prodotte da DermaTriage possono essere sottoposte a revisione da parte del personale medico. La validazione consente di confermare l'esito proposto dal sistema oppure di registrare una correzione, mantenuta come feedback associato alla diagnosi.

Gli esiti validati possono essere recuperati anche attraverso l'integrazione con B4. Le correzioni registrate alimentano due meccanismi distinti: l'evoluzione dei prompt utilizza

gli esempi corretti più recenti, mentre le discordanze tra l'esito del sistema e la valutazione medica vengono raccolte per il successivo retraining di EfficientNet-B4. I due meccanismi sono descritti rispettivamente nelle Sezioni 1.4.2 e 1.4.3.

1.4.2. Evoluzione dei prompt

L'aggiornamento dei prompt è gestito dal componente **PromptManager**. Il sistema tiene traccia delle correzioni effettuate durante la revisione delle diagnosi. L'aggiornamento viene attivato ogni dieci correzioni e utilizza una finestra scorrevole composta dai venti esempi più recenti.

Le diverse versioni vengono mantenute in modo persistente, permettendo di distinguere il prompt attualmente utilizzato da quelli prodotti in precedenza. Il meccanismo riguarda i prompt associati a Qwen2-VL e BioMistral e consente di modificarne le istruzioni mantenendo invariati i rispettivi parametri.

1.4.3. Retraining del classificatore EfficientNet-B4

Il retraining di EfficientNet-B4 viene attivato al raggiungimento di 50 correzioni associate a casi in cui l'esito prodotto dal sistema risulta discordante rispetto alla valutazione del personale medico. Il controllo viene eseguito tramite un trigger event-driven e il ciclo può essere avviato anche manualmente attraverso le funzionalità amministrative dedicate.

Per costruire i dati necessari al nuovo ciclo di addestramento, DermaTriage recupera tramite B4 i consulti e le relative immagini. Ai fini del retraining vengono utilizzati file JPEG e PNG, mentre i documenti PDF sono esclusi. Le priorità cliniche validate vengono ricondotte alle classi del classificatore secondo la corrispondenza P1/P2-HIGH, P3-MEDIUM e P4-LOW.

Il fine-tuning interessa gli ultimi due blocchi di feature extraction e la testa di classificazione di EfficientNet-B4. Ogni ciclo prevede 10 epoche, con learning rate pari a 5×10^{-6} per il backbone e 3×10^{-5} per il classificatore. I pesi di classe [3.0, 2.0, 1.0] assegnano maggiore importanza alla classe HIGH durante l'aggiornamento.

1.4.4. Validazione tecnica e gestione delle versioni

Prima che una nuova versione del classificatore sostituisca quella in uso, le sue prestazioni vengono confrontate con i valori di riferimento del modello precedente. La validazione considera in particolare la sensibilità sulla classe HIGH, la frequenza dei casi urgenti classificati erroneamente come LOW e l'accuratezza complessiva.

L'aggiornamento non deve peggiorare la sensibilità sui casi HIGH né aumentare i falsi LOW; inoltre, l'accuratezza complessiva non può diminuire di oltre cinque punti percentuali rispetto al riferimento. Come baseline vengono utilizzati una sensibilità HIGH del 90.24%, un tasso di falsi LOW del 7.93% e un'accuratezza complessiva dell'81.74%.

I checkpoint prodotti dai cicli di retraining vengono conservati come versioni distinte del classificatore. È inoltre previsto un checkpoint di backup della versione attiva, utilizzabile per ripristinare il modello precedente. Il rollback automatico è previsto nel caso in cui l'accuratezza della nuova versione diminuisca di oltre il 5% rispetto al modello attivo.

Le informazioni sulle diverse versioni e sulla cronologia dei cicli di retraining vengono mantenute in modo persistente, permettendo di ricostruire gli aggiornamenti effettuati nel tempo.

2. Identificazione degli asset

DermaTriage comprende diversi asset che concorrono al processo di triage e al mantenimento della pipeline nel tempo. Oltre ai dati clinici acquisiti per ciascun caso, rientrano tra gli asset le informazioni prodotte durante l'inferenza, i dataset e le strutture di persistenza, i modelli AI e gli artefatti utilizzati nei processi di aggiornamento e validazione.

Le dipendenze tra questi elementi consentono agli effetti di un eventuale malfunzionamento di propagarsi tra differenti stadi della pipeline. Gli asset comprendono quindi sia le risorse direttamente coinvolte nella determinazione della priorità clinica, sia quelle necessarie al recupero delle informazioni e all'evoluzione del sistema.

2.1. Dati clinici e input

Il processo di triage riceve come input l'immagine della lesione e le informazioni cliniche associate al paziente, tra cui età, sesso, localizzazione anatomica e sintomatologia disponibile. Nel flusso integrato con B4, ogni richiesta è inoltre associata a un consulto specifico, il cui identificativo consente di mantenere il corretto collegamento tra i dati acquisiti, l'elaborazione effettuata e il risultato prodotto da DermaTriage.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A01	Immagine dermatologica	Dato clinico grezzo	Fornisce l'informazione visiva della lesione utilizzata per la classificazione dell'urgenza e la generazione della descrizione clinica.	Input: immagine della lesione acquisita tramite B4 o <code>/analyze</code> . Output: fornita a EfficientNet-B4 e Qwen2-VL.	Acquisizione e inferenza
A02	Dati clinici, demografici e sintomatologia	Dato clinico strutturato	Fornisce il contesto clinico e demografico complementare all'immagine e contribuisce alla successiva elaborazione del caso.	Input: età, sesso, localizzazione anatomica e sintomatologia disponibile. Output: informazioni contestuali utilizzate nella pipeline; i sintomi alimentano la sintesi clinica di BioMistral.	Acquisizione e inferenza
A03	Identificativo del consulto	Metadato applicativo	Identifica la richiesta B4 e mantiene l'associazione tra il consulto, i dati elaborati e il relativo risultato.	Input: <code>consulto_id</code> ricevuto tramite <code>/diagnose</code> . Output: riferimento utilizzato per recuperare il caso e associare il risultato alla richiesta corrispondente.	Integrazione e gestione del caso

Tabella 1: Asset relativi ai dati clinici e agli input di DermaTriage.

2.2. Inferenze e risultati della pipeline

Durante l’inferenza, i diversi stadi della pipeline producono informazioni intermedie che vengono progressivamente combinate fino alla determinazione della priorità clinica finale. Tali risultati comprendono la classificazione iniziale dell’urgenza, la descrizione clinica della lesione, i casi simili recuperati dal sistema RAG e la successiva sintesi clinica.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A04	Classificazione di urgenza EfficientNet-B4	Inferenza del modello	Fornisce una prima valutazione dell’urgenza della lesione, utilizzata dagli stadi successivi della pipeline.	Input: immagine dermatologica. Output: classe HIGH, MEDIUM o LOW, confidence e probabilità associate.	Inferenza - Stage 1
A05	Descrizione clinica Qwen2-VL	Inferenza del modello	Produce una descrizione strutturata delle caratteristiche visibili della lesione, utilizzata per contestualizzare il caso.	Input: immagine dermatologica. Output: descrizione di forma, bordi, colore, texture e caratteristiche sospette della lesione.	Inferenza - Stage 2
A06	Casi clinici simili recuperati dal RAG	Informazione recuperata	Fornisce precedenti clinici semanticamente simili al caso corrente come supporto alla successiva sintesi clinica.	Input: descrizione clinica della lesione. Output: cinque casi simili con diagnosi, urgenza, similarità e relativo identificativo anonimizzato.	Inferenza - Stage 3
A07	Sintesi clinica BioMistral	Inferenza del modello	Integra i risultati degli stadi precedenti e la sintomatologia disponibile per formulare una valutazione clinica complessiva.	Input: risultati degli Stage 1-3 e sintomi. Output: urgenza finale, confidence, reasoning, azione raccomandata e patologia prevista.	Inferenza - Stage 4
A08	Risultato finale di triage	Output clinico	Esprime la priorità clinica restituita dal sistema e costituisce il risultato conclusivo del processo di triage.	Input: sintesi clinica e logica dell’Adaptation Layer. Output: priorità P1-P4 e informazioni associate al risultato.	Decisione finale

Tabella 2: Asset relativi alle inferenze e ai risultati prodotti dalla pipeline di DermaTriage.

2.3. Dataset e persistenza

DermaTriage utilizza diverse risorse persistenti per supportare il recupero dei casi clinici, l’addestramento e la valutazione del classificatore e la conservazione dei risultati prodotti

durante l'esecuzione. Questi asset comprendono sia dati strutturati sia rappresentazioni indicizzate utilizzate direttamente dalla pipeline.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A09	Dataset clinico RAG	Dataset clinico	Conserva i casi clinici utilizzati come base informativa per il retrieval dei casi simili e come base per la preparazione dei dati del classificatore.	Input: casi clinici strutturati con descrizione clinica, diagnosi, livello di urgenza e relativi metadati. Output: base informativa utilizzata per la costruzione dell'indice vettoriale ChromaDB e per la preparazione dei dati del classificatore.	Persistenza e preparazione dati
A10	Indice vettoriale ChromaDB	Indice vettoriale	Memorizza e indicizza le rappresentazioni vettoriali delle descrizioni cliniche, consentendo la ricerca per similarità semantica.	Input: embedding delle descrizioni cliniche indicizzate e embedding della query. Output: riferimenti ai cinque casi più simili e relativi valori di similarità, utilizzati dal sistema RAG per costruire il risultato del retrieval.	Persistenza e inferenza - Stage 3
A11	Dati di training, validation e test	Dataset ML	Supporta l'addestramento, la selezione del modello e la valutazione delle prestazioni di EfficientNet-B4.	Input: immagini, metadati e dati derivati dalla preparazione del dataset. Output: split distinti per training, validation e test utilizzati nel ciclo di sviluppo del modello.	Training e validazione
A12	Storico delle diagnosi	Dato persistente	Conserva localmente i risultati diagnostici prodotti da DermaTriage e ne supporta la consultazione e la gestione successiva.	Input: risultati prodotti dalle richieste di triage. Output: diagnosi archiviate e disponibili per la consultazione e per eventuali revisioni successive.	Persistenza dei risultati

Tabella 3: Asset relativi ai dataset e alle risorse persistenti di DermaTriage.

2.4. Feedback e aggiornamento

Il mantenimento della pipeline utilizza gli esiti della validazione clinica per aggiornare nel tempo alcuni dei suoi componenti. Le conferme e le correzioni effettuate dal personale

medico alimentano l'evoluzione dei prompt e, in caso di discordanza con il risultato prodotto dal sistema, il retraining di EfficientNet-B4. Le nuove versioni del classificatore sono inoltre sottoposte a criteri di validazione prima della loro adozione.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A13	Feedback clinico validato	Dato clinico validato	Raccoglie le conferme e le correzioni effettuate dal personale medico e fornisce il riferimento clinico utilizzato nei processi di aggiornamento del sistema.	Input: esito prodotto da DermaTriage e successiva validazione medica. Output: conferme o correzioni utilizzate per l'evoluzione dei prompt e, nei casi discordanti, per il retraining di EfficientNet-B4.	Validazione e aggiornamento
A14	Prompt e storico delle versioni	Artefatto AI	Contiene le istruzioni utilizzate da Qwen2-VL e BioMistral e conserva le relative versioni generate dal processo di evoluzione dei prompt.	Input: correzioni cliniche recenti utilizzate per aggiornare i prompt. Output: prompt aggiornati utilizzati dai modelli generativi durante l'inferenza.	Aggiornamento e inferenza
A15	Metriche e criteri di accettazione del modello	Artefatto di validazione	Definisce i riferimenti utilizzati per confrontare una nuova versione di EfficientNet-B4 con il modello attualmente in uso prima della sua adozione.	Input: prestazioni della nuova versione e valori di riferimento del modello attivo. Output: valutazione basata su sensibilità HIGH, falsi LOW e accuratezza complessiva, utilizzata nella decisione di adozione o rollback.	Validazione del modello

Tabella 4: Asset relativi al feedback clinico e ai processi di aggiornamento di DermaTriage.

2.5. Modelli e artefatti AI

La pipeline di DermaTriage utilizza più modelli con funzioni distinte e complementari. EfficientNet-B4 effettua la classificazione iniziale dell'urgenza, Qwen2-VL produce la descrizione clinica della lesione, BioMistral integra le informazioni disponibili nella sintesi clinica e all-MiniLM-L6-v2 genera le rappresentazioni vettoriali utilizzate dal sistema RAG. Al classificatore EfficientNet-B4 è inoltre associato il checkpoint contenente i parametri appresi utilizzati durante l'esecuzione.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A16	Modello EfficientNet-B4	Modello di classificazione	Analizza l'immagine dermatologica e fornisce la prima classificazione dell'urgenza utilizzata dagli stadi successivi della pipeline. Il suo comportamento è determinato dai parametri appresi durante l'addestramento e caricati dal checkpoint attivo.	Input: immagine dermatologica e parametri del modello caricati dal checkpoint. Output: classe HIGH, MEDIUM o LOW, confidence e probabilità associate.	Training e inferenza - Stage 1
A17	Modello Qwen2-VL	Modello multimediale	Analizza visivamente la lesione e genera una descrizione clinica strutturata utilizzata negli stadi successivi della pipeline.	Input: immagine dermatologica e prompt. Output: descrizione di forma, bordi, colore, texture e caratteristiche sospette della lesione.	Inferenza - Stage 2
A18	Modello BioMistral	Modello linguistico	Integra le informazioni prodotte dagli stadi precedenti e la sintomatologia disponibile per generare la sintesi clinica complessiva del caso.	Input: classificazione di urgenza, descrizione clinica, casi simili, sintomi e prompt. Output: urgenza finale, confidence, reasoning, azione raccomandata e patologia prevista.	Inferenza - Stage 4
A19	Modello all-MiniLM-L6-v2	Modello di embedding	Genera le rappresentazioni vettoriali delle descrizioni cliniche utilizzate per confrontare semanticamente il caso corrente con i casi indicizzati in ChromaDB.	Input: descrizione clinica testuale. Output: embedding utilizzato per la ricerca dei casi semanticamente simili.	Retrieval - Stage 3

Tabella 5: Asset relativi ai modelli e agli artefatti AI di DermaTriage.

2.6. Logica decisionale

Al termine della pipeline di inferenza, il risultato prodotto da BioMistral viene trasformato nella scala di priorità clinica utilizzata da DermaTriage. Questa conversione è regolata dall'Adaptation Layer, che applica criteri deterministici al livello di urgenza e alla relativa confidenza per assegnare la priorità finale da P1 a P4.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A20	Regole dell'Adaptation Layer	Logica decisionale	Converte il livello di urgenza prodotto dalla pipeline nella priorità clinica P1-P4 applicando le regole previste per il triage.	Input: livello di urgenza e relativa confidenza. Output: priorità P1-P4, specialista indicato e relativo SLA.	Decisione finale

Tabella 6: Asset relativo alla logica decisionale finale di DermaTriage.

2.7. Servizi applicativi e configurazione

L'esecuzione della pipeline di DermaTriage dipende anche dai servizi che gestiscono l'interazione con l'esterno e l'accesso alle funzionalità del sistema. La piattaforma B4 supporta lo scambio delle informazioni relative ai consulti, mentre il servizio applicativo FastAPI espone le funzionalità di DermaTriage. A questi componenti si affianca la configurazione operativa, che definisce i parametri e le credenziali necessari al loro funzionamento.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A21	Piattaforma B4	Servizio esterno	Gestisce l'interazione con il paziente e rende disponibili a DermaTriage le informazioni associate ai consulti, supportando inoltre la restituzione e la successiva validazione dei risultati.	Input: dati e documenti associati al consulto e risultati prodotti da DermaTriage. Output: informazioni del consulto, immagini e risultati validati accessibili a DermaTriage tramite API.	Acquisizione, integrazione e aggiornamento
A22	Servizio applicativo FastAPI	Servizio applicativo	Esponde le funzionalità di DermaTriage e gestisce le richieste necessarie all'accesso alla pipeline di inferenza e alle altre operazioni applicative.	Input: richieste ricevute attraverso gli endpoint applicativi. Output: attivazione delle operazioni richieste e restituzione dei relativi risultati.	Esecuzione e integrazione
A23	Configurazione operativa e credenziali	Artefatto di configurazione	Definisce i parametri necessari al caricamento delle risorse, all'esecuzione della pipeline e all'autenticazione verso i servizi protetti e la piattaforma B4.	Input: variabili d'ambiente relative a percorsi, modelli, parametri operativi e credenziali. Output: configurazione utilizzata dai componenti di DermaTriage durante esecuzione, integrazione e retraining.	Configurazione ed esecuzione

Tabella 7: Asset relativi ai servizi applicativi e alla configurazione di DermaTriage.

3. Failure Mode and Effects Analysis

La Failure Mode and Effects Analysis (FMEA) è una metodologia utilizzata per identificare le possibili modalità di guasto di un sistema e valutarne le conseguenze. L'analisi si concentra sugli asset ritenuti maggiormente significativi per il funzionamento della pipeline, a partire da quelli individuati nell'Asset Model. Per ciascun asset vengono esaminate le funzioni svolte, i relativi prerequisiti e i possibili failure mode, individuandone cause ed effetti sugli altri componenti del sistema.

I failure mode considerati possono derivare sia da condizioni accidentali sia da azioni intenzionali in grado di alterare il normale comportamento dell'asset. L'eventuale corrispondenza con specifiche minacce di sicurezza viene analizzata successivamente mediante STRIDE-AI.

3.1. A01 - Immagine dermatologica

L'asset A01 rappresenta l'immagine della lesione dermatologica acquisita per il caso clinico e utilizzata come principale informazione visiva della pipeline. L'immagine può essere recuperata tramite B4 oppure fornita direttamente attraverso l'endpoint `/analyze`.

All'interno della pipeline, viene utilizzata nello Stage 1 da EfficientNet-B4 per la classificazione iniziale dell'urgenza e nello Stage 2 da Qwen2-VL per la generazione della descrizione clinica della lesione. La correttezza e l'adeguatezza dell'immagine costituiscono quindi un prerequisito per le successive elaborazioni visive.

3.1.1. Funzioni e prerequisiti

Le principali funzioni dell'asset e i prerequisiti necessari al loro svolgimento sono riportati nella Tabella 8.

ID	Funzione	Prerequisiti
F01.1	Rappresentazione visiva della lesione	Acquisizione di un'immagine che rappresenti in modo adeguato la lesione dermatologica oggetto del consulto.
F01.2	Associazione dell'immagine al caso clinico	Corretta corrispondenza tra l'immagine acquisita e il consulto o la richiesta di analisi a cui essa appartiene.
F01.3	Fornitura dell'input visivo alla pipeline di inferenza	Disponibilità dell'immagine in un formato utilizzabile e corretta trasmissione dell'input a EfficientNet-B4 nello Stage 1 e a Qwen2-VL nello Stage 2.
F01.4	Protezione della riservatezza dell'immagine	Accesso all'immagine consentito esclusivamente ai soggetti e ai componenti autorizzati durante l'acquisizione, il trasferimento e l'elaborazione all'interno della pipeline.

Tabella 8: Funzioni e prerequisiti dell'asset A01 - Immagine dermatologica.

3.1.2. Failure mode

Sulla base delle funzioni individuate vengono considerate le principali modalità con cui l'asset A01 può non svolgere correttamente il proprio compito, ovvero i failure mode.

ID	Failure mode	Possibili cause	Effetti
FM01.1	Immagine di qualità insufficiente	Sfocatura, illuminazione inadeguata, risoluzione insufficiente, presenza di artefatti oppure condizioni di acquisizione che rendono poco distinguibili le caratteristiche della lesione.	L'immagine non rappresenta con sufficiente chiarezza le caratteristiche della lesione, riducendo l'affidabilità delle elaborazioni di EfficientNet-B4 e Qwen2-VL.
FM01.2	Lesione rappresentata in modo incompleto o non adeguato	Inquadratura parziale, porzione rilevante della lesione esclusa dall'immagine oppure acquisizione di una regione cutanea che non consente di osservare adeguatamente la lesione di interesse.	I modelli ricevono una rappresentazione visiva incompleta e possono produrre una classificazione o una descrizione clinica non rappresentativa della lesione effettiva.
FM01.3	Immagine associata al caso clinico errato	Errata associazione tra immagine e consulto, selezione del documento non corrispondente al caso oppure errore nella gestione del riferimento utilizzato per recuperare l'immagine.	La pipeline elabora un'immagine non coerente con le informazioni cliniche della richiesta, producendo inferenze riferite al caso errato.
FM01.4	Manipolazione intenzionale dell'immagine	Alterazione deliberata del contenuto visivo, introduzione di perturbazioni o modifica dell'immagine prima dell'invio alla pipeline con l'obiettivo di influenzare l'elaborazione dei modelli.	EfficientNet-B4 e Qwen2-VL ricevono un input apparentemente valido ma alterato, con possibile modifica della classificazione dell'urgenza o della descrizione clinica prodotta.
FM01.5	Immagine non disponibile o non utilizzabile dalla pipeline	Formato non supportato, file danneggiato, errore nella lettura, mancato recupero dal servizio di origine oppure errore durante il trasferimento.	EfficientNet-B4 e Qwen2-VL non dispongono di un input visivo utilizzabile e non possono completare normalmente le rispettive elaborazioni.

Continua nella pagina successiva

ID	Failure mode	Possibili cause	Effetti
FM01.6	Esposizione non autorizzata dell'immagine dermatologica	Accesso non autorizzato all'immagine durante il trasferimento o l'elaborazione, configurazione errata dei controlli di accesso oppure esposizione accidentale dell'input attraverso i componenti coinvolti nel flusso di elaborazione.	L'immagine dermatologica può essere resa accessibile a soggetti o componenti non autorizzati, compromettendo la confidenzialità dell'informazione clinica e la privacy del paziente.

Tabella 9: Failure mode individuati per l'asset A01 - Immagine dermatologica.

3.2. A13 - Feedback clinico validato

L'asset A13 rappresenta il feedback clinico prodotto durante la revisione medica dei risultati generati da DermaTriage. Il feedback consente di confermare oppure correggere l'esito del sistema e viene associato al relativo caso clinico.

Le correzioni validate possono essere utilizzate nei meccanismi di aggiornamento della pipeline. In particolare, contribuiscono all'evoluzione dei prompt utilizzati dai modelli generativi e, nei casi di disaccordo con la classificazione precedente, possono concorrere all'attivazione del retraining del classificatore EfficientNet-B4.

Il feedback clinico rappresenta quindi un collegamento diretto tra la revisione medica e il ciclo di aggiornamento del sistema.

3.2.1. Funzioni e prerequisiti

Le principali funzioni dell'asset e i prerequisiti necessari al loro svolgimento sono riportati nella Tabella 10.

ID	Funzione	Prerequisiti
F13.1	Rappresentazione dell'esito della revisione medica	Disponibilità del risultato diagnostico da revisionare e corretta associazione tra valutazione del medico e relativo caso clinico.
F13.2	Fornitura di esempi validati per l'aggiornamento dei prompt	Disponibilità di correzioni cliniche correttamente registrate e utilizzabili dal meccanismo di evoluzione dei prompt.
F13.3	Supporto al retraining del classificatore	Presenza di correzioni che evidenziano un disaccordo rispetto alla classificazione precedente e disponibilità dei relativi dati clinici necessari al processo di aggiornamento del modello.

Tabella 10: Funzioni e prerequisiti dell'asset A13 - Feedback clinico validato.

3.2.2. Failure mode

Sulla base delle funzioni individuate vengono considerate le principali modalità con cui l'asset A13 può non svolgere correttamente il proprio compito, ovvero i failure mode.

ID	Failure mode	Possibili cause	Effetti
FM13.1	Feedback contenente istruzioni o contenuti avversariali	Inserimento intenzionale nel feedback di testo costruito per influenzare i successivi meccanismi di evoluzione dei prompt oppure utilizzo di correzioni contenenti istruzioni non pertinenti al contenuto clinico.	Gli esempi utilizzati per aggiornare i prompt possono incorporare contenuti avversariali e influenzare il comportamento successivo di Qwen2-VL o BioMistral.
FM13.2	Feedback associato al caso clinico errato	Collegamento non corretto tra correzione e diagnosi, utilizzo di un identificativo del consulto errato oppure errore nella registrazione della relazione tra feedback e caso.	Una correzione valida può essere applicata a un caso differente, introducendo informazioni incoerenti nel ciclo di aggiornamento.
FM13.3	Feedback clinico incompleto o non disponibile	Mancata registrazione della revisione, campi necessari non valorizzati oppure indisponibilità della correzione nel momento in cui deve essere utilizzata.	I processi di aggiornamento dispongono di informazioni validate insufficienti e possono non attivarsi o operare su una base incompleta.
FM13.4	Feedback clinico alterato o non autentico	Modifica non autorizzata di una correzione registrata, sostituzione dell'esito validato oppure inserimento di feedback falsi da parte di un soggetto non autorizzato.	Il sistema può utilizzare informazioni manipolate per l'aggiornamento dei prompt o per il retraining, propagando l'alterazione alle versioni successive della pipeline.

Tabella 11: Failure mode individuati per l'asset A13 - Feedback clinico validato.

3.3. A16 - Modello EfficientNet-B4

L'asset A16 riguarda il modello EfficientNet-B4 utilizzato per la classificazione iniziale dell'urgenza dermatologica e i parametri appresi durante l'addestramento, caricati dal checkpoint attivo. A partire dall'immagine della lesione, il modello produce una classe di urgenza tra HIGH, MEDIUM e LOW, insieme alla confidence della classificazione e alle probabilità associate alle diverse classi.

Il risultato dello Stage 1 viene utilizzato dalle successive elaborazioni della pipeline e contribuisce alla sintesi clinica prodotta da BioMistral e alla successiva determinazione della priorità P1-P4.

3.3.1. Funzioni e prerequisiti

Le principali funzioni dell'asset e i prerequisiti necessari al loro svolgimento sono riportati nella Tabella 12.

ID	Funzione	Prerequisiti
F16.1	Estrazione delle caratteristiche visive	Disponibilità di un'immagine dermatologica acquisita correttamente (A01) e caricamento del modello con i relativi parametri.
F16.2	Classificazione dell'urgenza in HIGH, MEDIUM o LOW	Corretta elaborazione dell'immagine e utilizzo dei parametri previsti per la versione attiva del classificatore.
F16.3	Produzione della confidence e delle probabilità associate	Completamento corretto dell'inferenza e disponibilità dell'output numerico prodotto dal classificatore.
F16.4	Utilizzo della versione prevista del modello	Disponibilità del checkpoint attivo e corretta configurazione dei riferimenti utilizzati per il caricamento del modello (A23).

Tabella 12: Funzioni e prerequisiti dell'asset A16 - Modello EfficientNet-B4 e relativi pesi.

3.3.2. Failure mode

Sulla base delle funzioni individuate vengono considerate le principali modalità con cui l'asset A16 può non svolgere correttamente il proprio compito, ovvero i failure mode.

ID	Failure mode	Possibili cause	Effetti
FM16.1	Estrazione inadeguata delle caratteristiche visive	Qualità insufficiente dell'immagine, presenza di artefatti visivi oppure inquadratura non adeguata della lesione.	Le caratteristiche ricavate dall'immagine non rappresentano adeguatamente la lesione, compromettendo l'informazione utilizzata per determinare la classe di urgenza.
FM16.2	Classificazione errata dell'urgenza	Limiti di generalizzazione del modello, distribuzione dei casi operativi differente da quella osservata durante l'addestramento oppure insufficiente capacità discriminativa tra le classi.	Il modello può sovrastimare o sotto-stimare l'urgenza, propagando l'errore agli stadi successivi e contribuendo a una valutazione finale non appropriata.
FM16.3	Confidence o probabilità non coerenti con la classificazione	Calibrazione non adeguata delle probabilità oppure comportamento eccessivamente confidente su campioni incerti o poco rappresentativi.	Gli stadi successivi ricevono una stima non attendibile dell'incertezza associata alla classificazione.

Continua nella pagina successiva

ID	Failure mode	Possibili cause	Effetti
FM16.4	Alterazione o sostituzione non autorizzata dei pesi o del checkpoint	Modifica deliberata dei parametri del modello, sostituzione del checkpoint attivo con una versione differente o compromessa, oppure caricamento di una versione non validata.	Il classificatore può produrre inferenze sistematicamente diverse da quelle previste pur continuando ad apparire operativo.
FM16.5	Output di inferenza incompleto o non disponibile	Errore durante l'esecuzione del modello, incompatibilità tra input, modello e parametri caricati oppure anomalia software che interrompe l'elaborazione prima del completamento.	Lo Stage 1 non fornisce classe, confidence o probabilità utilizzabili, impedendo agli stadi dipendenti di proseguire normalmente.

Tabella 13: Failure mode individuati per l'asset A16 - Modello EfficientNet-B4 e relativi pesi.

3.4. A20 - Regole dell'Adaptation Layer

L'asset A20 rappresenta l'insieme delle regole utilizzate dall'Adaptation Layer per convertire il livello di urgenza prodotto dalla pipeline nella scala clinica P1-P4 utilizzata dal sistema di triage.

La conversione considera la classe di urgenza HIGH, MEDIUM o LOW e, per i casi classificati come HIGH, anche il livello di confidence. Un caso HIGH con confidence superiore a 0.85 viene associato alla priorità P1, mentre gli altri casi HIGH vengono assegnati a P2. Le classi MEDIUM e LOW vengono convertite rispettivamente in P3 e P4.

L'Adaptation Layer produce inoltre le informazioni associate alla priorità finale, tra cui lo specialista indicato e il relativo SLA. Le regole di mapping costituiscono quindi il passaggio conclusivo tra il risultato interno della pipeline di inferenza e la rappresentazione clinica restituita dal sistema.

3.4.1. Funzioni e prerequisiti

Le principali funzioni dell'asset e i prerequisiti necessari al loro svolgimento sono riportati nella Tabella 14.

ID	Funzione	Prerequisiti
F20.1	Traduzione dell'output di BioMistral nel risultato operativo di triage	Disponibilità di un output strutturato di BioMistral contenente il livello finale di urgenza e la relativa confidence, insieme alla corretta applicazione delle regole che determinano priorità P1-P4, specialista e SLA.
F20.2	Associazione delle indicazioni operative alla priorità assegnata	Disponibilità della priorità P1-P4 determinata e corretta corrispondenza con lo specialista e lo SLA previsti per il relativo livello di presa in carico.

Tabella 14: Funzioni e prerequisiti dell'asset A20 - Regole dell'Adaptation Layer.

3.4.2. Failure mode

Sulla base delle funzioni individuate vengono considerate le principali modalità con cui l'asset A20 può non svolgere correttamente il proprio compito, ovvero i failure mode.

ID	Failure mode	Possibili cause	Effetti
FM20.1	Interpretazione errata dell'output di BioMistral	Output strutturato incompleto o inatteso, errore nella lettura dei campi restituiti, utilizzo di un valore differente da <code>final_urgency</code> oppure gestione non corretta della confidence associata.	L'Adaptation Layer utilizza informazioni diverse da quelle effettivamente prodotte da BioMistral e può determinare una priorità P1-P4 non coerente con il risultato dello Stage 4.
FM20.2	Determinazione errata della priorità clinica	Definizione non corretta della corrispondenza tra HIGH, MEDIUM, LOW e P1-P4 oppure applicazione errata della soglia di confidence utilizzata per distinguere i casi P1 e P2.	Un output correttamente interpretato può essere trasformato in una priorità clinica diversa da quella prevista dalle regole dell'Adaptation Layer.
FM20.3	Alterazione intenzionale delle regole di mapping	Modifica non autorizzata della corrispondenza tra livelli di urgenza e priorità, variazione deliberata della soglia di confidence oppure sostituzione della logica di mapping prevista.	Il sistema può continuare a produrre risultati formalmente validi assegnando però sistematicamente priorità differenti da quelle previste.
FM20.4	Produzione incompleta o incoerente del risultato operativo	Mancata valorizzazione di priorità, specialista o SLA oppure associazione non coerente tra questi elementi nell'output prodotto dall'Adaptation Layer.	Il risultato finale del triage può risultare incompleto oppure contenere indicazioni operative non coerenti con la priorità assegnata.

Tabella 15: Failure mode individuati per l'asset A20 - Regole dell'Adaptation Layer.

3.5. A21 - Piattaforma B4

L'asset A21 rappresenta la piattaforma esterna B4, utilizzata come principale punto di interazione tra DermaTriage e il flusso clinico. Attraverso le API messe a disposizione dalla piattaforma, DermaTriage può recuperare i consulti e i relativi documenti, acquisire l'immagine dermatologica necessaria all'elaborazione e restituire il risultato diagnostico prodotto dalla pipeline.

B4 supporta inoltre la gestione delle validazioni mediche associate ai risultati di triage. Gli esiti clinici validati possono essere recuperati a DermaTriage e utilizzati nei meccanismi di aggiornamento del sistema, tra cui l'evoluzione dei prompt e il retraining del classificatore EfficientNet-B4. L'accesso alle API B4 avviene mediante autenticazione basata su Bearer JWT.

3.5.1. Funzioni e prerequisiti

Le principali funzioni dell'asset e i prerequisiti necessari al loro svolgimento sono riportati nella Tabella 16.

ID	Funzione	Prerequisiti
F21.1	Raccolta e organizzazione delle informazioni del consulto	Presenza di una richiesta di triage correttamente identificata e associazione coerente tra dati clinici, informazioni demografiche e documenti caricati dal paziente.
F21.2	Messa a disposizione controllata dei dati necessari a DermaTriage	Presenza sulla piattaforma delle informazioni e dei documenti associati al consulto, disponibilità delle API necessarie al loro recupero e accesso consentito esclusivamente attraverso i meccanismi di autenticazione e autorizzazione previsti.
F21.3	Conservazione del risultato diagnostico e della validazione medica	Corretta identificazione del consulto a cui associare il risultato prodotto da DermaTriage e l'eventuale successiva valutazione del personale medico.
F21.4	Supporto al ciclo di aggiornamento di DermaTriage	Disponibilità di consulti, immagini ed esiti clinici validati utilizzabili dai processi di aggiornamento dei componenti della pipeline.

Tabella 16: Funzioni e prerequisiti dell'asset A21 - Piattaforma B4.

3.5.2. Failure mode

Sulla base delle funzioni individuate vengono considerate le principali modalità con cui l'asset A21 può non svolgere correttamente il proprio compito, ovvero i failure mode.

ID	Failure mode	Possibili cause	Effetti
FM21.1	Dati del consulto incompleti o incoerenti	Informazioni cliniche mancanti, documenti non presenti, inconsistenza tra dati demografici, sintomi e documentazione oppure registrazione incompleta del consulto.	DermaTriage riceve una rappresentazione incompleta o incoerente del caso, riducendo l'affidabilità delle successive elaborazioni.
FM21.2	Manipolazione intenzionale dei dati o dei documenti del consulto	Modifica non autorizzata di informazioni cliniche, sostituzione dei documenti associati al consulto oppure alterazione dei riferimenti utilizzati per identificare il caso.	DermaTriage può elaborare informazioni intenzionalmente alterate o appartenenti a un caso differente, producendo un risultato di triage non corrispondente al caso reale.
FM21.3	Stato delle informazioni non correttamente aggiornato sulla piattaforma	Mancato aggiornamento del risultato diagnostico o della validazione, registrazione incompleta dello stato del consulto oppure persistenza di informazioni obsolete rispetto all'ultima elaborazione disponibile.	B4 può mantenere uno stato del caso non aggiornato, compromettendo la revisione medica o il successivo utilizzo del feedback clinico.
FM21.4	Servizi B4 non disponibili o non accessibili	Indisponibilità della piattaforma o delle API, problemi di autenticazione, mancato rilascio o rinnovo del Bearer JWT, interruzioni della comunicazione oppure sovraccarico intenzionale delle funzionalità esposte.	DermaTriage non può accedere alle funzionalità B4 necessarie, causando l'interruzione parziale o completa del flusso integrato.
FM21.5	Esposizione non autorizzata dei dati clinici del consulto	Configurazione errata dei controlli di accesso, compromissione o uso improprio delle credenziali, dell'API key o del Bearer JWT, oppure accesso alle informazioni del consulto da parte di soggetti o componenti non autorizzati.	Immagini dermatologiche, dati clinici e demografici, documenti, risultati diagnostici o validazioni mediche possono essere resi disponibili a soggetti non autorizzati, compromettendo direttamente la confidenzialità delle informazioni e la privacy del paziente.

Tabella 17: Failure mode individuati per l'asset A21 - Piattaforma B4.

4. Security Properties e Threat Mapping

I failure mode individuati nel capitolo precedente vengono utilizzati come punto di partenza per identificare le proprietà di sicurezza rilevanti e le eventuali minacce applicabili agli asset selezionati. L'analisi segue l'approccio STRIDE-AI, nel quale le proprietà di sicurezza vengono definite attraverso il modello CIA³-R e successivamente associate alle corrispondenti categorie STRIDE.

Non tutti i failure mode corrispondono necessariamente a una minaccia di sicurezza. Alcuni possono infatti derivare da errori, malfunzionamenti o limiti intrinseci del sistema, mentre altri possono essere causati o sfruttati intenzionalmente da un soggetto avversario. Il mapping STRIDE-AI viene quindi applicato soltanto ai failure mode per i quali è plausibile individuare un'azione intenzionale in grado di causarli o sfruttarli.

4.1. Proprietà di sicurezza CIA³-R

Il modello CIA³-R considera sei proprietà di sicurezza: *autenticità*, *integrità*, *non ripudiabilità*, *confidenzialità*, *disponibilità* e *autorizzazione*. Nel contesto di DermaTriage tali proprietà vengono selezionate in funzione delle caratteristiche dell'asset e del failure mode considerato, senza assumere che tutte siano rilevanti per ciascun componente.

Proprietà	Significato	Categoria STRIDE
Authenticity	Possibilità di verificare l'origine dell'informazione o dell'output	Spoofing
Integrity	Protezione da modifiche o inserimenti non autorizzati	Tampering
Non-repudiation	Possibilità di attribuire un'operazione o un output senza che possa essere successivamente disconosciuto	Repudiation
Confidentiality	Protezione delle informazioni da accessi o esposizioni non autorizzate	Information Disclosure
Availability	Disponibilità dell'asset e capacità del sistema di produrre un output utile quando richiesto	Denial of Service
Authorization	Utilizzo delle funzionalità e accesso agli output esclusivamente da parte di soggetti autorizzati	Elevation of Privilege

Tabella 18: Proprietà CIA³-R e corrispondenza con le categorie STRIDE-AI

4.2. Mapping STRIDE-AI

Per ciascun asset critico vengono analizzati i failure mode già individuati nella FMEA, identificando le proprietà CIA³-R coinvolte e distinguendo le condizioni accidentali da

quelle che possono derivare da un'azione intenzionale. Soltanto in quest'ultimo caso viene associata una categoria STRIDE-AI.

4.2.1. A01 - Immagine dermatologica

L'immagine dermatologica costituisce l'input visivo utilizzato da EfficientNet-B4 e Qwen2-VL. I failure mode relativi alla qualità o all'adeguatezza dell'acquisizione possono compromettere l'affidabilità dell'elaborazione senza implicare necessariamente un attaccante. Diversamente, la manipolazione deliberata dell'immagine costituisce una violazione dell'integrità, mentre la sua indisponibilità può assumere natura di Denial of Service qualora sia provocata intenzionalmente.

ID	Failure mode	CIA ³ -R	Natura	STRIDE-AI
FM01.1	Immagine di qualità insufficiente	Integrità in senso funzionale ¹	Prevalentemente - accidentale	
FM01.2	Lesione rappresentata in modo incompleto o non adeguato	Integrità in senso funzionale	Prevalentemente - accidentale	
FM01.3	Immagine associata al caso clinico errato	Integrity; Authenticity se l'associazione viene falsificata intenzionalmente	Accidentale o intenzionale	Tampering; eventualmen- te Spoofing
FM01.4	Manipolazione intenzionale dell'immagine	Integrity	Intenzionale	Tampering
FM01.5	Immagine non disponibile o non utilizzabile dalla pipeline	Availability	Accidentale o intenzionale	Denial of Service se intenzionale
FM01.6	Esposizione non autorizzata dell'immagine dermatologica	Confidentiality	Accidentale o intenzionale	Information Disclosure se intenzionale

Tabella 19: Mapping CIA³-R e STRIDE-AI dei failure mode dell'asset A01

4.2.2. A13 - Feedback clinico validato

Il feedback clinico validato rappresenta il riferimento utilizzato dai meccanismi di aggiornamento della pipeline, contribuendo sia all'evoluzione dei prompt sia, nei casi previsti, al retraining di EfficientNet-B4. La sua alterazione o manipolazione può quindi propagarsi alle versioni successive del sistema, mentre errori di associazione o indisponibilità possono verificarsi anche in assenza di un'azione avversaria.

¹Con *integrità in senso funzionale* si indica che il dato non è sufficientemente corretto, completo o adeguato rispetto alla funzione che deve svolgere nella pipeline; ciò non implica necessariamente una violazione della proprietà *Integrity* nel significato STRIDE-AI.

ID	Failure mode	CIA ³ -R	Natura	STRIDE-AI
FM13.1	Feedback contenente istruzioni o contenuti avversariali	Integrity	Intenzionale	Tampering
FM13.2	Feedback associato al caso clinico errato	Integrity; Authenticity se l'associazione viene falsificata intenzionalmente	Accidentale o intenzionale	Tampering; eventualmente Spoofing
FM13.3	Feedback clinico incompleto o non disponibile	Availability	Prevalentemente accidentale; potenzialmente intenzionale	Denial of Service se intenzionale
FM13.4	Feedback clinico alterato o non autentico	Integrity; Authenticity	Intenzionale	Tampering; Spoofing

Tabella 20: Mapping CIA³-R e STRIDE-AI dei failure mode dell'asset A13

4.2.3. A16 - Modello EfficientNet-B4

EfficientNet-B4 esegue la classificazione iniziale dell'urgenza dermatologica, producendo la classe HIGH, MEDIUM o LOW insieme a confidence e probabilità associate. Alcuni failure mode derivano da limiti prestazionali o comportamenti non affidabili anche in assenza di un attaccante; altri, come la modifica dei pesi o del checkpoint attivo, sono invece direttamente riconducibili a una compromissione intenzionale.

ID	Failure mode	CIA ³ -R	Natura	STRIDE-AI
FM16.1	Estrazione inadeguata delle caratteristiche visive	Integrità in senso funzionale	Prevalentemente accidentale	-
FM16.2	Classificazione errata dell'urgenza	Integrità in senso funzionale	Prevalentemente accidentale	-
FM16.3	Confidence o probabilità non coerenti con la classificazione	Integrità in senso funzionale	Prevalentemente accidentale	-
FM16.4	Alterazione o sostituzione non autorizzata dei pesi o del checkpoint	Integrity; Authenticity se viene sostituita la versione legittima del modello	Intenzionale	Tampering; eventualmente Spoofing
FM16.5	Output di inferenza incompleto o non disponibile	Availability	Accidentale o intenzionale	Denial of Service se intenzionale

Tabella 21: Mapping CIA³-R e STRIDE-AI dei failure mode dell'asset A16

4.2.4. A20 - Regole dell'Adaptation Layer

Le regole dell'Adaptation Layer determinano la conversione del risultato prodotto da BioMistral nella priorità clinica P1-P4 e nelle relative indicazioni operative. Errori nell'interpretazione dell'output o nella logica di mapping possono verificarsi anche in assenza di un attaccante, mentre la modifica deliberata delle regole o delle soglie costituisce una compromissione diretta della logica decisionale. Anche la produzione di un risultato operativo incompleto o inutilizzabile può compromettere la disponibilità dell'output finale.

ID	Failure mode	CIA ³ -R	Natura	STRIDE-AI
FM20.1	Interpretazione errata dell'output di BioMistral	Integrità in senso funzionale	Prevalentemente - accidentale	
FM20.2	Determinazione errata della priorità clinica	Integrità in senso funzionale	Prevalentemente - accidentale	
FM20.3	Alterazione intenzionale delle regole di mapping	Integrity; Authorization se la modifica richiede privilegi non autorizzati	Intenzionale	Tampering; eventualmente Elevation of Privilege
FM20.4	Produzione incompleta o incoerente del risultato operativo	Availability	Prevalentemente accidentale; potenzialmente intenzionale	Denial of Service se intenzionale

Tabella 22: Mapping CIA³-R e STRIDE-AI dei failure mode dell'asset A20

4.2.5. A21 - Piattaforma B4

La piattaforma B4 gestisce la raccolta e la disponibilità delle informazioni associate ai consulti, supportando inoltre la restituzione dei risultati diagnostici e delle successive validazioni mediche. I failure mode possono riguardare sia la qualità e coerenza delle informazioni mantenute sulla piattaforma, sia alterazioni intenzionali dei dati o indisponibilità dei servizi esposti tramite API.

ID	Failure mode	CIA ³ -R	Natura	STRIDE-AI
FM21.1	Dati del consulto incompleti o incoerenti	Integrità in senso funzionale	Prevalentemente - accidentale	
FM21.2	Manipolazione intenzionale dei dati o dei documenti del consulto	Integrity; Authenticity se vengono falsificati i riferimenti o l'origine dei dati	Intenzionale	Tampering; eventualmente Spoofing

Continua nella pagina successiva

ID	Failure mode	CIA ³ -R	Natura	STRIDE-AI
FM21.3	Stato delle informazioni non correttamente aggiornato sulla piattaforma	Integrità in senso funzionale	Prevalentemente - accidentale	-
FM21.4	Servizi B4 non disponibili o non accessibili	Availability	Accidentale o intenzionale	Denial of Service se intenzionale
FM21.5	Esposizione non autorizzata dei dati clinici del consulto	Confidentiality	Accidentale o intenzionale	Information Disclosure se intenzionale

Tabella 23: Mapping CIA³-R e STRIDE-AI dei failure mode dell'asset A21

4.3. Mapping OWASP AI e Agentic AI

Il mapping STRIDE-AI viene completato confrontando le minacce individuate con i rischi descritti da OWASP per applicazioni basate su modelli generativi e sistemi agentici. Le categorie OWASP vengono considerate soltanto quando descrivono una modalità di compromissione effettivamente pertinente all'architettura o ai failure mode già individuati per DermaTriage.

Per i componenti AI della pipeline viene preso come riferimento l'OWASP Top 10 for LLMs and GenAI Apps, utilizzato per ricondurre le minacce individuate a rischi specifici dell'impiego di modelli generativi, come la manipolazione degli input, la contaminazione dei dati o dei modelli e la compromissione dei componenti della supply chain. I rischi relativi ai sistemi agentici vengono invece considerati separatamente, poiché presuppongono capacità di autonomia, pianificazione e azione che non sono attualmente presenti in DermaTriage.

ID	Asset	Rischio OWASP	Impatto su DermaTriage
FM01.4 A01		<i>LLM01:2026 - Prompt Injection</i> (ramo multimodale Qwen2-VL)	La manipolazione intenzionale dell'immagine può assumere, nel ramo multimodale basato su Qwen2-VL, la forma di una prompt injection visiva, poiché contenuti o perturbazioni incorporati nell'immagine possono influenzare il comportamento del modello e alterare la descrizione clinica generata. Tale effetto può propagarsi agli stadi successivi della pipeline, incidendo sull'affidabilità del risultato finale e sulla sicurezza clinica. La stessa immagine manipolata può inoltre influenzare anche lo Stage 1, causando una classificazione errata da parte di EfficientNet-B4, pur non trattandosi in questo caso di prompt injection.

Continua nella pagina successiva

ID	Asset	Rischio OWASP	Impatto su DermaTriage
FM13.1 A13		<i>LLM01:2026 - Prompt Injection; LLM05:2026 - Data and Model Poisoning</i> se il contenuto viene incorporato nell'evoluzione dei prompt	Istruzioni avversariali presenti nel feedback possono influenzare il comportamento dei modelli quando il contenuto viene riutilizzato nell'evoluzione dei prompt. Se tale influenza viene mantenuta nelle versioni successive, la compromissione può propagarsi nel tempo, incidendo sull'affidabilità e sull'accountability del processo di aggiornamento e, indirettamente, sulla sicurezza delle successive decisioni cliniche.
FM16.4 A16		<i>LLM05:2026 - Data and Model Poisoning; LLM04:2026 - Supply Chain</i> qualora sia compromessa la provenienza o la distribuzione del checkpoint	L'alterazione dei pesi modifica direttamente il comportamento di EfficientNet-B4, mentre la sostituzione del checkpoint con un artefatto non affidabile introduce anche un problema di provenienza e supply chain. Il classificatore può rimanere apparentemente operativo pur producendo risultati sistematicamente alterati, con conseguenze sull'affidabilità dello Stage 1, sulla tracciabilità della versione impiegata e sulla priorità clinica finale.
FM20.3 A20		<i>LLM07:2026 - Misinformation</i>	L'alterazione intenzionale delle regole dell'Adaptation Layer può trasformare un risultato correttamente prodotto dagli stadi precedenti in una priorità P1-P4 non corrispondente a quella prevista. Il sistema può quindi restituire un'indicazione clinica formalmente plausibile ma fuorviante, che può essere considerata affidabile e utilizzata per la successiva presa in carico del paziente. La compromissione incide sull'affidabilità della decisione finale e può determinare una sottostima o sovrastima dell'urgenza, con conseguenze dirette sulla sicurezza clinica.
FM21.5 A21		<i>LLM02:2026 - Sensitive Information Disclosure</i>	L'accesso o l'esposizione non autorizzata delle informazioni associate al consulto può rendere disponibili a soggetti non autorizzati immagini dermatologiche, dati clinici e demografici, documenti, risultati o validazioni mediche. Nel contesto della pipeline AI il rischio è riconducibile a <i>Sensitive Information Disclosure</i> quando tali informazioni vengono esposte attraverso il contesto utilizzato dai modelli, i dati recuperati o gli output prodotti. L'impatto riguarda direttamente la sicurezza e la privacy del paziente e può compromettere l'accountability qualora non sia possibile ricostruire l'origine e l'estensione della divulgazione.

Tabella 24: Mapping delle minacce di DermaTriage con corrispondenza pertinente nei rischi OWASP GenAI 2026

4.3.1. Applicabilità dei rischi Agentic AI

I rischi dell'OWASP Top 10 for Agentic Applications vengono considerati separatamente, poiché si riferiscono a sistemi in cui i modelli possono pianificare attività, utilizzare strumenti, mantenere memoria o contesto persistente e compiere azioni autonome sui sistemi collegati. Queste caratteristiche non sono presenti nell'architettura attuale di DermaTriage; Qwen2-VL e BioMistral operano all'interno di una pipeline orchestrata dall'applicazione, mentre l'Adaptation Layer applica regole deterministiche. I modelli, inoltre, non interagiscono autonomamente con B4 o con altri servizi esterni.

Alcuni failure mode già associati ai rischi OWASP GenAI potrebbero tuttavia assumere una dimensione agantica in una futura evoluzione del sistema. In particolare, FM01.4 e FM13.1 potrebbero essere ricondotti a *ASI01 - Agent Goal Hijack* qualora una manipolazione dell'immagine o contenuti avversariali presenti nel feedback riuscissero a modificare gli obiettivi perseguiti da un agente o a influenzarne le azioni autonome.

FM13.1 presenta inoltre una possibile relazione con *ASI06 - Memory & Context Poisoning* qualora il contenuto contaminato venisse memorizzato come contesto persistente e riutilizzato nelle elaborazioni successive, rendendo duraturo nel tempo l'effetto della compromissione.

FM16.4 può invece essere associato a *ASI04 - Agentic Supply Chain Vulnerabilities* qualora un modello o checkpoint compromesso venisse integrato nel runtime agentic, influenzando il comportamento dell'agente e compromettendone l'affidabilità complessiva.

Infine, FM20.3 potrebbe essere associato a *ASI08 - Cascading Failures* qualora una priorità clinica alterata venisse utilizzata autonomamente da altri componenti o agenti per determinare azioni successive, propagando l'errore lungo il workflow.

Tali categorie non risultano quindi direttamente applicabili all'architettura attuale di DermaTriage, ma potrebbero diventare rilevanti in presenza di maggiore autonomia decisionale, utilizzo di strumenti, memoria persistente o interazione diretta dei modelli con servizi esterni.

5. Risk Assessment

La prioritizzazione dei rischi viene effettuata mediante un approccio a due livelli, coerente con l'analisi sviluppata nei capitoli precedenti. In una prima fase vengono valutati tutti i failure mode individuati nella FMEA attraverso il Risk Priority Number (RPN), mentre in una fase successiva le minacce di sicurezza selezionate vengono ulteriormente analizzate mediante DREAD.

L'RPN consente di confrontare i failure mode considerando tre fattori: la gravità delle conseguenze (*Severity*), la probabilità relativa di occorrenza (*Occurrence*) e la difficoltà di rilevazione prima che il failure produca effetti (*Detection*). Il valore viene calcolato come:

$$RPN = S \times O \times D$$

con ciascun parametro valutato su una scala da 1 a 10. I punteggi non rappresentano probabilità statistiche assolute, ma stime qualitative motivate sulla base dell'architettura, delle cause e degli effetti già individuati nella FMEA.

La valutazione DREAD viene invece applicata successivamente alle minacce di sicurezza ritenute maggiormente rilevanti, considerando *Damage Potential*, *Reproducibility*, *Exploitability*, *Affected Users* e *Discoverability*. In questo modo l'RPN fornisce una prima valutazione della criticità dei failure mode, mentre DREAD permette di approfondire la priorità delle minacce dal punto di vista della sicurezza.

5.1. Valutazione RPN dei failure mode

Per ciascun failure mode vengono assegnati i valori di *Severity*, *Occurrence* e *Detection* su una scala da 1 a 10. La valutazione è effettuata in modo comparativo rispetto al contesto specifico di DermaTriage, così da mantenere coerente l'assegnazione dei punteggi tra i diversi failure mode.

In particolare, la *Severity* assume valori più elevati quando il failure può incidere direttamente sulla priorità clinica, compromettere in modo persistente il comportamento della pipeline o causare un'esposizione significativa di dati clinici. L'*Occurrence* cresce per condizioni che possono verificarsi più facilmente durante il normale esercizio del sistema, mentre viene ridotta per eventi che richiedono condizioni particolari o capacità specifiche da parte di un attaccante. La *Detection* è invece maggiore quando il failure può rimanere nascosto pur lasciando il sistema apparentemente operativo, ed è minore quando l'anomalia risulta immediatamente evidente.

I punteggi ottenuti non rappresentano quindi probabilità assolute, ma una misura relativa della criticità dei failure mode utile per confrontarli e supportare le successive fasi di prioritizzazione.

ID	Failure mode	S	O	D	RPN
FM01.1	Immagine di qualità insufficiente	7	7	3	147
FM01.2	Lesione rappresentata in modo incompleto o non adeguato	8	6	4	192
FM01.3	Immagine associata al caso clinico errato	9	3	7	189
FM01.4	Manipolazione intenzionale dell'immagine	9	4	7	252
FM01.5	Immagine non disponibile o non utilizzabile dalla pipeline	7	4	2	56
FM01.6	Esposizione non autorizzata dell'immagine dermatologica	7	3	7	147
FM13.1	Feedback contenente istruzioni o contenuti avversariali	9	3	8	216
FM13.2	Feedback associato al caso clinico errato	8	3	7	168
FM13.3	Feedback clinico incompleto o non disponibile	6	4	3	72
FM13.4	Feedback clinico alterato o non autentico	9	3	8	216
FM16.1	Estrazione inadeguata delle caratteristiche visive	7	5	6	210
FM16.2	Classificazione errata dell'urgenza	9	5	6	270
FM16.3	Confidence o probabilità non coerenti con la classificazione	8	4	8	256
FM16.4	Alterazione o sostituzione non autorizzata dei pesi o del checkpoint	10	2	9	180
FM16.5	Output di inferenza incompleto o non disponibile	7	3	2	42
FM20.1	Interpretazione errata dell'output di BioMistral	9	3	5	135
FM20.2	Determinazione errata della priorità clinica	10	3	6	180
FM20.3	Alterazione intenzionale delle regole di mapping	10	3	9	270
FM20.4	Produzione incompleta o incoerente del risultato operativo	8	3	3	72
FM21.1	Dati del consulto incompleti o incoerenti	8	4	4	128
FM21.2	Manipolazione intenzionale dei dati o dei documenti del consulto	9	3	8	216
FM21.3	Stato delle informazioni non correttamente aggiornato sulla piattaforma	7	4	6	168
FM21.4	Servizi B4 non disponibili o non accessibili	8	4	2	64
FM21.5	Esposizione non autorizzata dei dati clinici del consulto	10	3	8	240

Tabella 25: Valutazione RPN dei failure mode di DermaTriage

5.2. Valutazione DREAD delle minacce

La valutazione DREAD viene applicata alle minacce individuate mediante il mapping STRIDE-AI, con l'obiettivo di ottenere una prioritizzazione comparativa degli scenari di attacco più rilevanti.

Come primo criterio di selezione viene adottata, ai fini della presente analisi, una soglia pari a

$$RPN \geq 180,$$

così da concentrare l'attenzione sui failure mode caratterizzati da una criticità comparativamente elevata.

Il superamento della soglia RPN non è tuttavia sufficiente. La FMEA comprende infatti sia condizioni accidentali sia failure mode riconducibili a un'azione avversariale, mentre DREAD viene utilizzato per la valutazione delle minacce di sicurezza. Vengono quindi mantenuti soltanto i failure mode per i quali il mapping STRIDE-AI consente di individuare una concreta componente intenzionale riconducibile a una categoria STRIDE. Un failure mode può pertanto presentare un RPN elevato senza essere necessariamente sottoposto a DREAD.

Sulla base di tali criteri vengono sottoposti a DREAD i failure mode FM01.3, FM01.4, FM13.1, FM16.4, FM20.3, FM21.2 e FM21.5.

Per ciascuna minaccia vengono valutati *Damage Potential*, *Reproducibility*, *Exploitability*, *Affected Users* e *Discoverability*. Il punteggio ottenuto viene utilizzato come misura comparativa di priorità e non come valore assoluto del rischio, tenendo conto della componente soggettiva del metodo.

Nell'assegnazione dei punteggi viene mantenuta coerenza con la precedente valutazione FMEA. In particolare, il *Damage Potential* tiene conto della Severity già attribuita al failure mode e dell'eventuale propagazione della compromissione lungo la pipeline. Gli altri fattori vengono stimati considerando le caratteristiche concrete dell'architettura: possibilità di ripetere l'attacco, prerequisiti tecnici e privilegi necessari, numero di casi o componenti potenzialmente coinvolti e facilità di individuazione della superficie di attacco.

Il punteggio complessivo è calcolato come media dei cinque valori DREAD. Ai soli fini della lettura comparativa dei risultati, nel presente lavoro vengono considerate ad alta priorità le minacce con media almeno pari a 7, a priorità media quelle con valore maggiore o uguale a 5 e inferiore a 7, e a priorità bassa quelle con valore inferiore a 5.

ID	Minaccia valutata	D	R	E	A	D	Media	Priorità
FM01.3	Falsificazione dell'associazione tra immagine e caso clinico	9	5	5	4	5	5.6	Media
FM01.4	Manipolazione intenzionale dell'immagine	9	8	7	5	6	7	Alta
FM13.1	Inserimento di contenuti avversariali nel feedback clinico	9	6	5	8	5	6.6	Media

Continua nella pagina successiva

ID	Minaccia valutata	D	R	E	A	D	Media	Priorità
FM16.4	Alterazione o sostituzione non autorizzata del modello	10	5	4	9	4	6.4	Media
FM20.3	Alterazione intenzionale delle regole di mapping	10	8	4	9	5	7.2	Alta
FM21.2	Manipolazione dei dati o dei documenti del consulto	9	6	5	4	6	6.0	Media
FM21.5	Esposizione non autorizzata dei dati clinici	10	7	6	7	6	7.2	Alta

Tabella 26: Valutazione DREAD delle minacce selezionate per DermaTriage

I risultati evidenziano tre minacce a priorità alta: FM01.4, FM20.3 e FM21.5. La manipolazione intenzionale dell'immagine risulta particolarmente rilevante perché può essere ripetuta con relativa facilità e influenzare più stadi della pipeline. L'alterazione delle regole dell'Adaptation Layer può invece modificare in modo sistematico la priorità clinica pur lasciando il sistema apparentemente operativo, mentre l'esposizione non autorizzata dei dati clinici può coinvolgere informazioni sensibili associate a più consulti.

FM13.1 e FM16.4 presentano una criticità prossima alla fascia alta. Nel primo caso, contenuti avversariali inseriti nel feedback possono propagarsi attraverso i successivi meccanismi di aggiornamento; nel secondo, la compromissione del modello può produrre effetti persistenti sull'intera pipeline, pur richiedendo capacità o privilegi maggiori e risultando quindi meno facilmente sfruttabile.

FM01.3 e FM21.2 mantengono infine una priorità media, poiché i relativi effetti sono generalmente più circoscritti al singolo caso clinico rispetto alle minacce in grado di alterare stabilmente il comportamento del sistema o coinvolgere un numero maggiore di consulti.

5.3. Prioritizzazione finale

I risultati ottenuti mediante RPN e DREAD vengono sintetizzati attraverso una risk matrix qualitativa basata su due dimensioni: *Impact* e *Likelihood*. L'*Impact* tiene conto principalmente della Severity attribuita nella FMEA e del Damage Potential valutato mediante DREAD, mentre la *Likelihood* considera congiuntamente Occurrence, Reproducibility ed Exploitability.

La risk matrix viene quindi utilizzata come sintesi delle valutazioni precedenti e non come metodo di scoring indipendente. Per rendere uniforme l'interpretazione dei risultati, la combinazione tra Impact e Likelihood viene ricondotta ai livelli di rischio riportati nella Tabella 27.

Impact / Likelihood	Bassa	Media	Alta
Alto	Medio	Alto	Molto alto
Medio	Basso	Medio	Alto
Basso	Basso	Basso	Medio

Tabella 27: Criterio qualitativo utilizzato nella risk matrix.

Applicando tale criterio alle minacce già valutate mediante DREAD si ottiene la prioritizzazione finale riportata nella Tabella 28.

ID	Minaccia	Impact	Likelihood	Rischio
FM01.3	Falsificazione dell'associazione tra immagine e caso clinico	Alto	Media	Alto
FM01.4	Manipolazione intenzionale dell'immagine	Alto	Alta	Molto alto
FM13.1	Inserimento di contenuti avversariali nel feed-back clinico	Alto	Media	Alto
FM16.4	Alterazione o sostituzione non autorizzata del modello	Alto	Bassa	Medio
FM20.3	Alterazione intenzionale delle regole di mapping	Alto	Media	Alto
FM21.2	Manipolazione dei dati o dei documenti del consulto	Alto	Media	Alto
FM21.5	Esposizione non autorizzata dei dati clinici	Alto	Media	Alto

Tabella 28: Prioritizzazione finale delle minacce mediante risk matrix.

L'esito della valutazione evidenzia FM01.4 come minaccia a rischio molto alto. FM01.3, FM13.1, FM20.3, FM21.2 e FM21.5 risultano invece a rischio alto, mentre FM16.4 presenta un rischio medio a causa della minore Likelihood, pur mantenendo un impatto elevato.

I risultati ottenuti costituiscono la base per la selezione delle minacce da approfondire nei successivi threat scenario e threat tree.

6. Threat Scenarios e Threat Trees

A partire dalla prioritizzazione sviluppata nel Capitolo 5 vengono approfonditi gli scenari di attacco maggiormente rappresentativi per DermaTriage. La selezione considera il livello di rischio ottenuto, il potenziale impatto sul sistema e la necessità di rappresentare superfici di attacco differenti della pipeline.

In particolare, vengono analizzate quattro minacce: la manipolazione intenzionale dell'immagine dermatologica, l'inserimento di contenuti avversariali nel feedback clinico, l'alterazione delle regole dell'Adaptation Layer e l'esposizione non autorizzata dei dati clinici. Tali scenari coprono rispettivamente la fase di input, il ciclo di aggiornamento, la logica decisionale finale e la protezione delle informazioni sensibili.

Per ciascuna minaccia viene descritto uno scenario realistico compatibile con l'architettura analizzata e viene successivamente costruito un threat tree. La radice rappresenta l'obiettivo dell'attaccante, mentre i rami descrivono modalità alternative o condizioni concorrenti attraverso cui la minaccia può essere realizzata. Le foglie identificano infine le principali precondizioni o capability necessarie per completare il percorso di attacco.

6.1. FM01.4 - Manipolazione intenzionale dell'immagine

Un attaccante tenta di alterare il risultato del triage facendo elaborare a DermaTriage un'immagine dermatologica intenzionalmente manipolata. La compromissione può avvenire direttamente in fase di input, intervenendo sull'immagine prima dell'invio attraverso B4 o l'endpoint `/analyze`, oppure durante le successive fasi di trasferimento e preparazione dell'immagine prima dell'inferenza.

L'immagine modificata può influenzare EfficientNet-B4 introducendo perturbazioni capaci di alterare la classificazione iniziale dell'urgenza. Parallelamente, nel ramo multimodale, contenuti visivi appositamente costruiti possono influenzare Qwen2-VL e determinare una descrizione clinica non corrispondente alle caratteristiche reali della lesione. Tale alterazione può propagarsi agli stadi successivi della pipeline, influenzando BioMistral e, infine, la priorità clinica P1-P4 prodotta dall'Adaptation Layer.

6.1.1. Threat tree

Il threat tree rappresenta le principali modalità attraverso cui può materializzarsi FM01.4. La radice coincide con la minaccia di *manipolazione intenzionale dell'immagine*, mentre i quattro rami principali sono collegati tramite una relazione OR, poiché ciascuno di essi può costituire un percorso sufficiente per compromettere l'input visivo elaborato dalla pipeline.

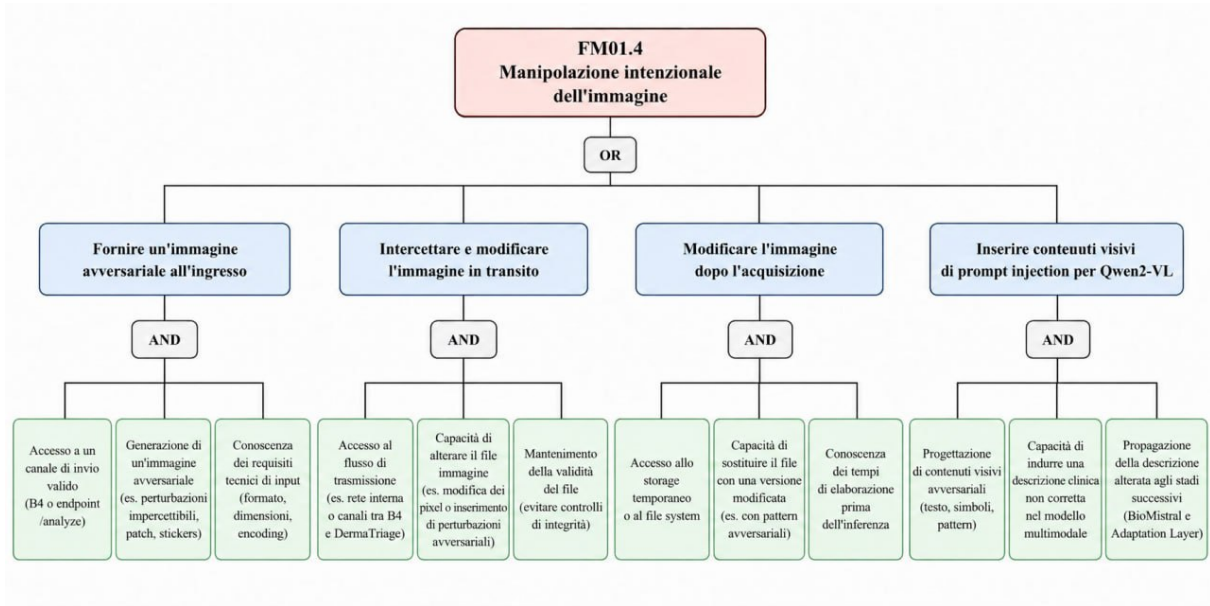


Figura 2: Threat tree relativo a FM01.4 - Manipolazione intenzionale dell'immagine

Il primo percorso considera l'invio diretto di un'immagine avversariale attraverso un canale di input valido, previa conoscenza dei requisiti tecnici richiesti dalla pipeline. Il secondo riguarda l'intercettazione e la modifica dell'immagine durante il trasferimento verso DermaTriage, mantenendo il file formalmente valido e utilizzabile dal sistema.

Il terzo percorso considera invece la modifica dell'immagine dopo l'acquisizione, attraverso l'accesso allo storage temporaneo o al file system utilizzato prima dell'inferenza. Il quarto riguarda specificamente Qwen2-VL e la possibilità di inserire nell'immagine contenuti visivi avversariali in grado di influenzare l'interpretazione del modello multimodale e propagare una descrizione alterata verso BioMistral e l'Adaptation Layer.

I diversi percorsi non sono necessariamente esclusivi. Una stessa immagine può, ad esempio, contenere perturbazioni rivolte a EfficientNet-B4 e componenti visive progettate per influenzare Qwen2-VL. Il threat tree evidenzia quindi le principali precondizioni e capability richieste all'attaccante.

6.2. FM13.1 - Contenuti avversariali nel feedback clinico

Un attaccante riesce a introdurre nel feedback clinico contenuti progettati per influenzare i successivi meccanismi di aggiornamento della pipeline. Il feedback può apparire formalmente valido e coerente con una revisione clinica, pur contenendo istruzioni o pattern semantici avversariali destinati a essere riutilizzati nel processo di evoluzione dei prompt.

La minaccia può manifestarsi sia attraverso l'inserimento iniziale di un feedback manipolato, sia mediante la modifica di una revisione già registrata. Se il contenuto contaminato

viene successivamente selezionato dal processo di aggiornamento e incorporato in una nuova versione del prompt, l'effetto può persistere nel tempo e influenzare le successive elaborazioni di Qwen2-VL o BioMistral.

6.2.1. Threat tree

La radice del threat tree coincide con la minaccia *FM13.1 - Contenuti avversariali nel feedback clinico*. I tre rami principali sono collegati tramite una relazione OR e rappresentano modalità alternative attraverso cui il contenuto avversariale può essere introdotto, modificato o fatto entrare nel processo di aggiornamento dei prompt.

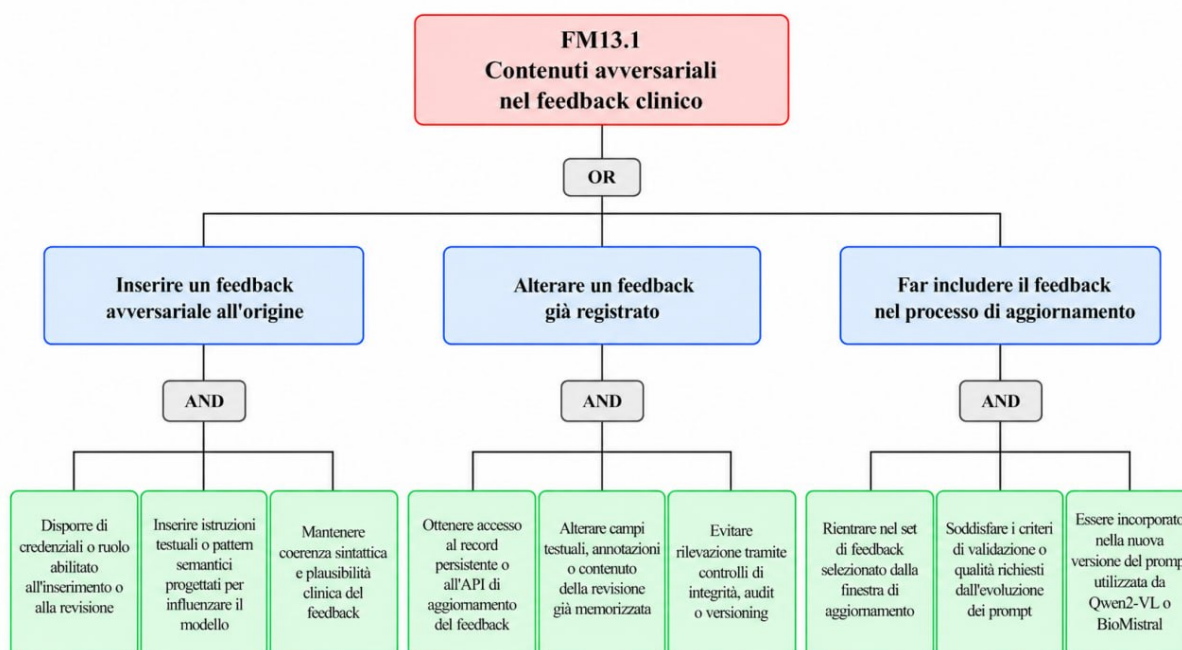


Figura 3: Threat tree relativo a FM13.1 - Contenuti avversariali nel feedback clinico

Il primo percorso riguarda l'inserimento diretto di un feedback avversariale all'origine. L'attaccante deve disporre di credenziali o di un ruolo che consenta l'inserimento o la revisione del feedback, costruire contenuti capaci di influenzare il comportamento dei modelli e mantenere al tempo stesso una plausibilità sintattica e clinica sufficiente a non rendere immediatamente evidente la manipolazione.

Il secondo percorso considera l'alterazione di un feedback già registrato. In questo caso è necessario ottenere accesso al record persistente o alle API di aggiornamento, modificare i campi rilevanti della revisione e superare eventuali meccanismi di controllo dell'integrità, audit o versionamento.

Il terzo percorso riguarda il passaggio del feedback contaminato nel processo di evoluzione dei prompt. Il contenuto deve rientrare nel set selezionato dalla finestra di aggiornamento, soddisfare i criteri previsti dal processo di evoluzione e venire infine incorporato nella nuova versione del prompt utilizzata da Qwen2-VL o BioMistral.

Il threat tree evidenzia quindi come la minaccia possa derivare da percorsi differenti ma convergere nello stesso effetto: l'utilizzo persistente di contenuti contaminati nel ciclo di aggiornamento della pipeline.

6.3. FM20.3 - Alterazione delle regole dell'Adaptation Layer

Un attaccante riesce a modificare intenzionalmente le regole utilizzate dall'Adaptation Layer per convertire il livello di urgenza prodotto dalla pipeline nella priorità clinica P1-P4. La compromissione può riguardare direttamente la logica di mapping, i parametri decisionali utilizzati dalla funzione oppure la versione delle regole caricata ed eseguita dal sistema.

La modifica può lasciare invariati gli stadi di inferenza precedenti: EfficientNet-B4, Qwen2-VL e BioMistral possono quindi produrre risultati formalmente corretti, mentre l'Adaptation Layer li converte secondo regole alterate. Il sistema può continuare ad apparire operativo pur assegnando in modo sistematico priorità, specialisti o SLA differenti da quelli previsti, con possibili conseguenze dirette sulla presa in carico del paziente.

6.3.1. Threat tree

La radice del threat tree coincide con la minaccia *FM20.3 - Alterazione intenzionale delle regole dell'Adaptation Layer*. I tre rami principali sono collegati tramite una relazione OR e rappresentano modalità alternative attraverso cui l'attaccante può compromettere la logica decisionale finale.

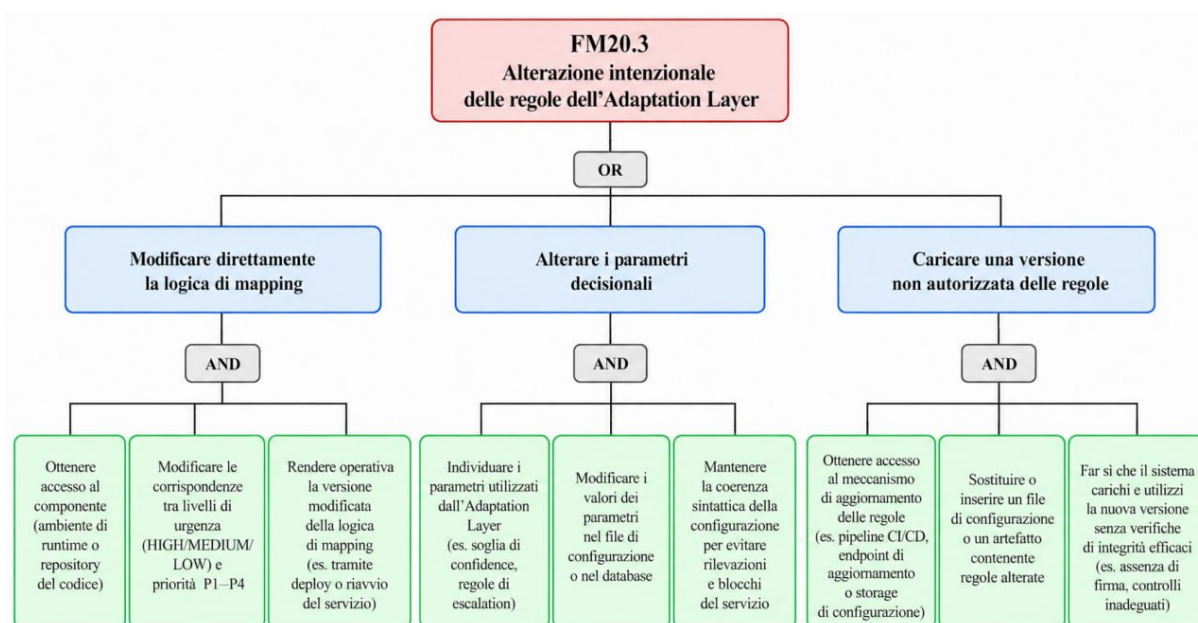


Figura 4: Threat tree relativo a FM20.3 - Alterazione intenzionale delle regole dell'Adaptation Layer

Il primo percorso riguarda la modifica diretta della logica di mapping. L'attaccante deve ottenere accesso al componente applicativo o al repository del codice, modificare le corrispondenze tra i livelli di urgenza HIGH/MEDIUM/LOW e le priorità P1–P4 e rendere operativa la versione alterata, ad esempio attraverso il normale meccanismo di deploy o il riavvio del servizio.

Il secondo percorso interessa i parametri decisionali utilizzati dall'Adaptation Layer, come la soglia di confidence impiegata per distinguere i casi HIGH assegnati a P1 da quelli assegnati a P2. La compromissione richiede l'individuazione dei parametri rilevanti, la modifica dei relativi valori nella configurazione o nella risorsa in cui sono memorizzati e il mantenimento di una configurazione formalmente valida, così da evitare errori immediatamente rilevabili.

Il terzo percorso consiste nel caricamento di una versione non autorizzata delle regole. In questo caso, l'attaccante deve ottenere l'accesso al meccanismo di aggiornamento di tali regole o configurazioni, al fine di iniettare un artefatto contenente la logica alterata e indurre il sistema ad adottarlo, eludendo i controlli di integrità o provenienza.

I tre percorsi convergono nello stesso effetto: un risultato di inferenza correttamente prodotto può essere trasformato in una priorità clinica non corrispondente alle regole previste. Poiché l'output può rimanere formalmente valido, la compromissione può risultare difficile da individuare e influenzare più richieste di triage prima di essere rilevata.

6.4. FM21.5 - Esposizione non autorizzata dei dati clinici

Un attaccante riesce ad accedere senza autorizzazione alle informazioni cliniche associate ai consulti gestiti tramite B4 e utilizzati da DermaTriage. I dati potenzialmente esposti comprendono immagini dermatologiche, dati clinici e anagrafici, documenti allegati, risultati diagnostici e validazioni mediche.

La compromissione può derivare dall'uso improprio dei meccanismi di autenticazione, dallo sfruttamento di controlli di autorizzazione insufficienti oppure dall'accesso diretto alle risorse che memorizzano o trasportano i dati. In tutti questi casi, informazioni destinate esclusivamente a soggetti o componenti autorizzati possono essere consultate, estratte o intercettate da un attaccante, con impatto diretto sulla confidenzialità e sulla privacy del paziente.

6.4.1. Threat tree

La radice del threat tree coincide con la minaccia *FM21.5 - Esposizione non autorizzata dei dati clinici*. I tre rami principali sono collegati tramite una relazione OR e rappresentano modalità alternative attraverso cui un attaccante può ottenere accesso a informazioni cliniche riservate.

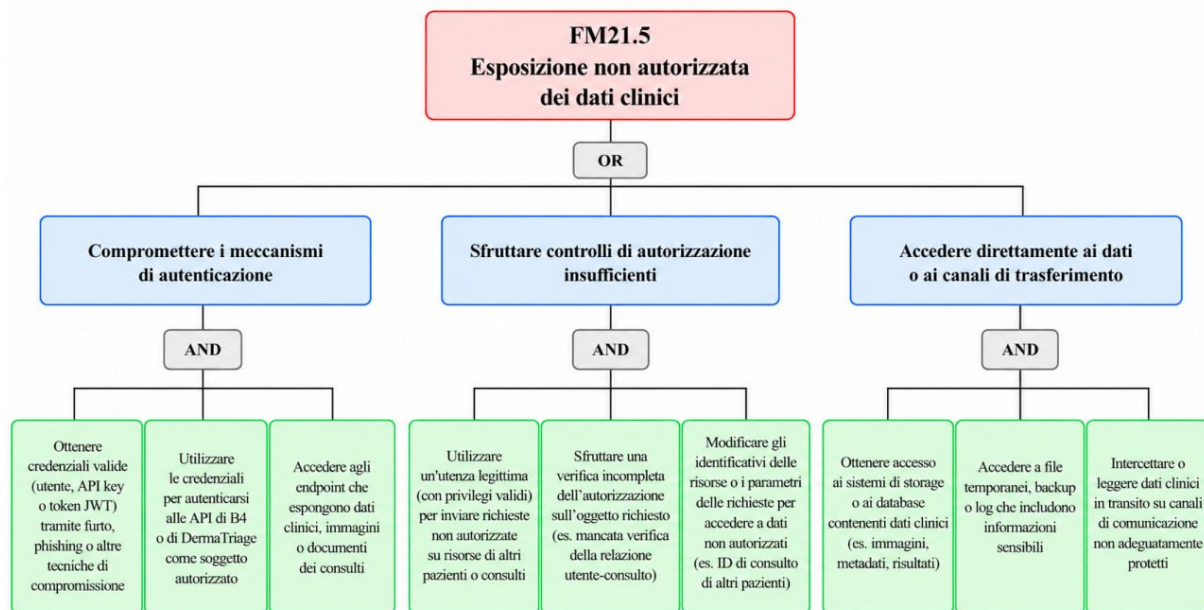


Figura 5: Threat tree relativo a FM21.5 - Esposizione non autorizzata dei dati clinici

Il primo percorso riguarda la compromissione dei meccanismi di autenticazione. L'attaccante deve ottenere credenziali valide, quali utenze, API key o token JWT, tramite furto, phishing o altre tecniche di compromissione, utilizzarle per autenticarsi alle API di B4 o di DermaTriage e accedere così agli endpoint che espongono dati clinici, immagini o documenti dei consulti.

Il secondo percorso considera lo sfruttamento di controlli di autorizzazione insufficienti. In questo caso l'attaccante opera come utente regolarmente autenticato, ma utilizza privilegi validi per inviare richieste non autorizzate su risorse riferite ad altri pazienti o consulti. La minaccia si concretizza quando il sistema applica verifiche incomplete sull'oggetto richiesto, ad esempio non controllando correttamente la relazione tra utente e consulto, oppure quando è possibile modificare identificativi o parametri della richiesta per accedere a dati non autorizzati.

Il terzo percorso riguarda l'accesso diretto ai dati o ai canali di trasferimento. L'attaccante può ottenere accesso ai sistemi di storage o ai database contenenti immagini, metadati e risultati, consultare file temporanei, backup o log che includono informazioni sensibili, oppure intercettare dati clinici in transito su canali di comunicazione non adeguatamente protetti.

I tre percorsi convergono nella stessa conseguenza: informazioni cliniche sensibili vengono rese disponibili a soggetti non autorizzati. La portata dell'esposizione dipende dal livello di accesso ottenuto e può riguardare un singolo consulto oppure un insieme più ampio di dati gestiti dal sistema.

7. Mitigation e Residual Risk

A partire dalle minacce approfondite nel Capitolo 6, vengono individuate le principali misure di mitigazione applicabili ai relativi percorsi di attacco, collegando ciascuna contromisura alle condizioni e alle precondizioni emerse nei threat tree.

Le contromisure considerate nel seguito sono formulate come interventi di sicurezza applicabili ai percorsi di attacco individuati, con l’obiettivo di ridurre la probabilità di successo della minaccia, aumentarne la rilevabilità e, quando possibile, limitarne la propagazione lungo la pipeline. L’effetto di tali misure non implica tuttavia l’eliminazione completa del rischio: le condizioni che rimangono sfruttabili anche dopo l’applicazione delle contromisure vengono considerate nella successiva valutazione del rischio residuo.

7.1. FM01.4 - Manipolazione intenzionale dell’immagine

Il threat tree associato a FM01.4 individua quattro principali modalità di compromissione dell’immagine dermatologica: la fornitura diretta di un input avversariale, la modifica dell’immagine durante il trasferimento, la sua alterazione dopo l’acquisizione e prima dell’inferenza e l’inserimento di contenuti visivi progettati per influenzare Qwen2-VL.

Le mitigazioni devono pertanto agire sia sulla superficie di ingresso sia sulla protezione dell’immagine durante il suo percorso nella pipeline. Poiché un’immagine formalmente valida può comunque contenere perturbazioni o contenuti avversariali, i soli controlli sul formato del file non risultano sufficienti. Per ciascun percorso vengono quindi considerate separatamente le principali precondizioni individuate nel threat tree, associando a ciascuna di esse una misura volta a impedirne lo sfruttamento o a renderlo più facilmente rilevabile.

Percorso di attacco	Mitigazioni delle precondizioni	Effetto atteso
Fornire un’immagine avversariale all’ingresso	1. Proteggere gli endpoint mediante API key o token autenticati e applicare rate limiting. 2. Verificare la stabilità dell’inferenza rispetto a resize o ricompressione, segnalando variazioni anomale di classe o confidence. 3. Decodificare e ricodificare lato server l’immagine nel formato e nelle dimensioni attese prima dell’inferenza.	Riduce la possibilità che un’immagine costruita intenzionalmente raggiunga EfficientNet-B4 e Qwen2-VL senza essere rilevata e rende più difficile mantenere perturbazioni efficaci dopo il preprocessing.

Continua nella pagina successiva

Percorso di attacco	Mitigazioni delle precondizioni	Effetto atteso
Intercettare e modificare l'immagine durante il trasferimento	1. Utilizzare TLS con verifica del certificato tra B4 e DermaTriage. 2. Associare all'immagine un HMAC-SHA-256 e verificarlo alla ricezione. 3. Vincolare il file ricevuto al relativo <code>consulto_id</code> e verificarne tipo e corretta decodifica.	Riduce la possibilità di intercettare, sostituire o modificare l'immagine durante il trasferimento e consente di rilevare alterazioni prima che il dato venga utilizzato dalla pipeline.
Modificare l'immagine dopo l'acquisizione e prima dell'inferenza	1. Utilizzare un service account dedicato con permessi minimi sulle directory temporanee. 2. Rendere l'immagine in sola lettura dopo l'acquisizione, limitando la scrittura alla sola fase iniziale. 3. Calcolare un digest SHA-256 dopo l'acquisizione e verificarlo prima del caricamento nei modelli.	Riduce la possibilità che un soggetto con accesso all'ambiente di esecuzione modifichi silenziosamente un'immagine già acquisita e permette di rilevare alterazioni intervenute prima dell'inferenza.
Inserire contenuti visivi avversariali destinati a Qwen2-VL	1. Rilevare testo sovrapposto o elementi estranei al contenuto clinico atteso. 2. Vincolare Qwen2-VL tramite system prompt al solo compito di descrizione clinica, trattando l'immagine come input non fidato. 3. Validare l'output e bloccare testo imperativo o campi estranei prima dell'invio al RAG e a BioMistral.	Riduce la probabilità che una visual prompt injection modifichi il comportamento di Qwen2-VL e limita la propagazione di una descrizione alterata verso il sistema RAG, BioMistral e gli stadi successivi.

Tabella 29: Mitigazioni proposte per FM01.4 in relazione alle precondizioni dei principali percorsi del threat tree

7.2. FM13.1 - Contenuti avversariali nel feedback clinico

Il threat tree associato a FM13.1 individua tre modalità attraverso cui un feedback clinico contaminato può influenzare l'aggiornamento della pipeline: l'inserimento di contenuti avversariali direttamente durante la revisione, l'alterazione di un feedback già registrato e la successiva inclusione del contenuto compromesso nel processo di evoluzione dei prompt.

Le mitigazioni devono quindi proteggere sia l'origine e la persistenza del feedback sia il suo utilizzo nel processo di aggiornamento. Particolare attenzione deve essere posta ai contenuti semanticamente avversariali ma clinicamente plausibili, che possono superare controlli esclusivamente sintattici e venire successivamente incorporati nelle nuove versioni dei prompt.

Percorso di attacco	Mitigazioni delle precondizioni	Effetto atteso
Inserire un feedback avversariale all'origine	1. Proteggere le funzioni di revisione mediante autenticazione nominativa, MFA e autorizzazione RBAC per i ruoli abilitati. 2. Preferire campi strutturati e valori ammessi per le correzioni, limitando il testo libero alle sole informazioni cliniche necessarie. 3. Sottoporre i feedback destinati all'aggiornamento a una seconda validazione prima che possano essere utilizzati dal PromptManager.	Riduce la possibilità che un soggetto non autorizzato o un singolo account compromesso introduca contenuti avversariali e limita l'ingresso di feedback manipolati nel processo di aggiornamento.
Alterare un feedback già registrato	1. Limitare l'accesso alle API e allo storage dei feedback mediante RBAC e permessi di scrittura separati da quelli di sola consultazione. 2. Conservare le revisioni come versioni distinte, evitando la sovrascrittura non tracciata del record clinico precedentemente validato. 3. Applicare HMAC ai record persistenti e mantenere audit log append-only delle operazioni di modifica.	Riduce la possibilità di modificare silenziosamente un feedback già validato e consente di rilevare alterazioni prima del suo riutilizzo nei processi di aggiornamento.
Far includere il feedback contaminato nel processo di aggiornamento	1. Includere nella finestra di aggiornamento soltanto feedback esplicitamente approvati e non semplicemente le correzioni più recenti. 2. Separare il contenuto del feedback dalle istruzioni del processo di evoluzione, trattandolo come dato non fidato all'interno del prompt. 3. Validare ogni nuova versione dei prompt su casi di riferimento prima dell'attivazione, mantenendo versionamento e possibilità di rollback.	Riduce la probabilità che un feedback contaminato venga incorporato nei prompt attivi e limita la persistenza dell'alterazione nelle successive elaborazioni di Qwen2-VL o BioMistral.

Tabella 30: Mitigazioni proposte per FM13.1 in relazione alle precondizioni dei principali percorsi del threat tree

7.3. FM20.3 - Alterazione delle regole dell'Adaptation Layer

Il threat tree associato a FM20.3 individua tre modalità attraverso cui un attaccante può compromettere la logica decisionale finale: la modifica diretta delle regole di mapping, l'alterazione dei parametri decisionali e il caricamento di una versione non autorizzata delle regole.

Le mitigazioni devono quindi proteggere sia il codice e la configurazione dell'Adaptation Layer sia il processo attraverso cui tali elementi vengono modificati o resi operativi. Poiché un'alterazione può produrre output formalmente validi ma clinicamente non coerenti con le regole previste, è necessario affiancare ai controlli di accesso anche verifiche di integrità, versionamento e validazione del comportamento decisionale.

Percorso di attacco	Mitigazioni delle precondizioni	Effetto atteso
Modificare direttamente la logica di mapping	1. Proteggere repository e componenti applicativi mediante RBAC, MFA e permessi di modifica limitati ai soli ruoli autorizzati. 2. Richiedere code review e approvazione prima del merge di modifiche alla funzione di mapping. 3. Eseguire test automatici che verifichino le corrispondenze HIGH/MEDIUM/LOW-P1/P4 e la soglia di confidence prima del deploy.	Riduce la possibilità di introdurre e rendere operativa una modifica non autorizzata della logica e permette di rilevare variazioni rispetto alle regole attese prima del rilascio.
Alterare i parametri decisionali	1. Separare i parametri decisionali dalla configurazione modificabile dagli utenti e limitarne l'accesso in scrittura ai soli componenti autorizzati. 2. Vincolare la soglia di confidence e gli altri valori critici a configurazioni versionate e sottoposte a controllo delle differenze. 3. Validare automaticamente la configurazione rispetto a valori ammessi e a casi di test rappresentativi prima del caricamento.	Riduce la possibilità di modificare silenziosamente i parametri utilizzati dall'Adaptation Layer e rende rilevabili variazioni capaci di alterare sistematicamente l'assegnazione della priorità.

Continua nella pagina successiva

Percorso di attacco	Mitigazioni delle precondizioni	Effetto atteso
Caricare una versione non autorizzata delle regole	1. Limitare l'accesso al meccanismo di deploy o aggiornamento mediante autenticazione forte e privilegi amministrativi separati. 2. Firmare l'artefatto contenente le regole e verificarne la firma prima del caricamento da parte del servizio. 3. Mantenere versionamento e hash della versione approvata, bloccando l'attivazione di artefatti non corrispondenti a una release autorizzata.	Riduce la possibilità di sostituire le regole con una versione alterata e impedisce l'attivazione di artefatti privi di provenienza o integrità verificabile.

Tabella 31: Mitigazioni proposte per FM20.3 in relazione alle precondizioni dei principali percorsi del threat tree

7.4. FM21.5 - Esposizione non autorizzata dei dati clinici

Il threat tree associato a FM21.5 individua tre modalità attraverso cui un attaccante può ottenere accesso a informazioni cliniche riservate: la compromissione dei meccanismi di autenticazione, lo sfruttamento di controlli di autorizzazione insufficienti e l'accesso diretto alle risorse che memorizzano o trasportano i dati.

Le mitigazioni devono quindi proteggere sia l'identità dei soggetti e dei componenti che accedono ai servizi, sia l'autorizzazione sulle singole risorse richieste, oltre ai dati conservati o trasferiti. Poiché un utente correttamente autenticato può comunque tentare di accedere a consulti appartenenti ad altri soggetti, autenticazione e autorizzazione devono essere trattate come controlli distinti.

Percorso di attacco	Mitigazioni delle precondizioni	Effetto atteso
Compromettere i meccanismi di autenticazione	1. Proteggere gli account privilegiati mediante MFA e limitare l'uso di credenziali condivise. 2. Applicare scadenza breve, rotazione e revoca di API key e JWT, evitando token persistenti oltre il necessario. 3. Applicare rate limiting e rilevazione di tentativi anomali sugli endpoint di autenticazione e sulle API che espongono dati clinici.	Riduce la possibilità che credenziali o token compromessi vengano riutilizzati con successo e limita l'accesso prolungato agli endpoint contenenti dati clinici.

Continua nella pagina successiva

Percorso di attacco	Mitigazioni delle precondizioni	Effetto atteso
Sfruttare controlli di autorizzazione insufficienti	1. Verificare lato server, per ogni richiesta, la relazione tra identità autenticata e <code>consulto_id</code> richiesto. 2. Applicare autorizzazione object-level anche a immagini, documenti, diagnosi e validazioni associate al consulto. 3. Rifiutare identificativi o parametri modificati che facciano riferimento a risorse non appartenenti al soggetto autorizzato.	Riduce la possibilità che un utente autenticato acceda a consulti o documenti di altri soggetti mediante modifica degli identificativi o abuso dei propri privilegi.
Accedere direttamente ai dati o ai canali di trasferimento	1. Cifrare database, backup e file persistenti contenenti dati clinici e limitare l'accesso mediante account di servizio dedicati. 2. Proteggere file temporanei e log mediante permessi minimi, evitando la registrazione di dati clinici non necessari. 3. Utilizzare TLS con verifica del certificato per le comunicazioni tra B4 e DermaTriage e per gli altri trasferimenti contenenti dati sensibili.	Riduce la possibilità di estrarre informazioni direttamente dallo storage, dai file ausiliari o dal traffico di rete senza utilizzare i normali meccanismi applicativi.

Tabella 32: Mitigazioni proposte per FM21.5 in relazione alle precondizioni dei principali percorsi del threat tree

7.5. Valutazione del rischio residuo

A seguito delle mitigazioni individuate, le quattro minacce vengono rivalutate utilizzando la stessa risk matrix qualitativa adottata nel Capitolo 5. Non viene quindi introdotto un nuovo metodo di scoring: Impact e Likelihood vengono riesaminati considerando l'effetto delle contromisure sui percorsi e sulle precondizioni individuate nei threat tree.

La rivalutazione considera sia la capacità delle misure preventive di rendere più difficile il completamento dell'attacco, sia i controlli di detection e recovery che possono limitarne gli effetti o impedirne la propagazione. Il livello residuo viene quindi ricavato combinando nuovamente Impact e Likelihood secondo la risk matrix già utilizzata nella prioritizzazione iniziale.

ID	Rischio iniziale	Impact residuo	Likelihood residua	Rischio residuo
FM01.4	Molto alto	Alto	Media	Alto
FM13.1	Alto	Medio	Bassa	Basso
FM20.3	Alto	Alto	Bassa	Medio
FM21.5	Alto	Alto	Bassa	Medio

Tabella 33: Valutazione del rischio residuo delle minacce analizzate

Per FM01.4 la Likelihood viene ridotta da Alta a Media. La protezione degli endpoint e dei canali di trasferimento, la normalizzazione dell'immagine e i controlli applicati al ramo multimodale rendono più difficile completare i percorsi di attacco individuati. L'Impact rimane Alto, poiché un input avversariale capace di superare tali controlli può ancora influenzare più stadi della pipeline e contribuire a una priorità clinica non corretta. Il rischio residuo viene quindi valutato come Alto.

Per FM13.1 la Likelihood viene ridotta da Media a Bassa grazie ai controlli sull'inserimento, sulla modifica e sulla selezione dei feedback destinati all'aggiornamento. L'Impact residuo viene valutato come Medio, poiché la validazione delle nuove versioni dei prompt, il versionamento e la possibilità di rollback limitano la persistenza e la propagazione di un eventuale contenuto contaminato. Il rischio residuo viene pertanto valutato come Basso.

Per FM20.3 la Likelihood viene ridotta da Media a Bassa. La protezione del codice e dei parametri decisionali, insieme a code review, test automatici, firma degli artefatti e controllo delle versioni, rende più difficile introdurre e attivare una logica di mapping alterata senza rilevazione. L'Impact rimane Alto, poiché una compromissione riuscita può modificare sistematicamente la priorità clinica e le relative indicazioni operative. Il rischio residuo viene quindi valutato come Medio.

Per FM21.5 la Likelihood viene ridotta da Media a Bassa. Autenticazione forte, autorizzazione sulle singole risorse, protezione dello storage e cifratura delle comunicazioni riducono i principali percorsi di accesso non autorizzato ai dati clinici. L'Impact rimane Alto per la sensibilità delle informazioni e per la possibile estensione dell'esposizione a più consulti. Il rischio residuo viene quindi valutato come Medio.

La valutazione evidenzia pertanto una riduzione del rischio per tutte le minacce considerate, senza assumere che le relative superfici di attacco possano essere completamente eliminate. FM01.4 mantiene il livello residuo più elevato, mentre FM13.1 beneficia anche di misure di contenimento e ripristino che ne riducono maggiormente gli effetti nel tempo.

7.6. Assunzioni, limiti e controlli non pienamente verificabili

L'analisi è sviluppata assumendo che l'architettura, i flussi di elaborazione, le regole decisionali e i meccanismi di aggiornamento descritti nella documentazione disponibile rappresentino la configurazione di riferimento di DermaTriage. Sono inoltre considerate le interazioni documentate con B4 e i componenti interni della pipeline, senza assumere la presenza di ulteriori meccanismi autonomi, strumenti esterni o forme di memoria persistente non descritte nell'architettura.

La documentazione consente di valutare i principali controlli e le superfici di attacco a livello architetturale, ma non permette di verificare completamente alcuni aspetti della configurazione operativa. Tra questi rientrano la granularità effettiva delle policy di autorizzazione sulle singole risorse, le modalità di rotazione e revoca delle credenziali, la configurazione concreta dei canali TLS, la cifratura dello storage e dei backup, la protezione dei log, l'isolamento dei processi e la configurazione del meccanismo di deploy.

Analogamente, non è possibile determinare dalla sola documentazione l'effettiva applicazione di controlli quali MFA, firma degli artefatti, verifiche HMAC, audit log append-only, separazione dei privilegi e procedure di approvazione delle modifiche. Tali misure sono pertanto considerate nel piano di mitigazione come controlli da applicare ai percorsi di attacco individuati, mentre la loro efficacia effettiva richiederebbe una verifica della configurazione distribuita e delle procedure operative adottate.

Restano inoltre fuori dal perimetro della presente analisi attività di verifica dinamica quali penetration test, adversarial testing dei modelli, revisione della configurazione runtime e test specifici sull'efficacia dei controlli di monitoraggio e rilevazione. Tali attività potrebbero essere utilizzate per validare sperimentalmente le ipotesi formulate nel threat model e affinare ulteriormente la stima del rischio residuo.

Nel complesso, l'analisi identifica le principali superfici di attacco di DermaTriage, ne valuta la priorità, ricostruisce i percorsi necessari alla loro realizzazione e associa a ciascuno di essi contromisure coerenti con l'architettura analizzata. La valutazione del rischio residuo completa infine il processo distinguendo il rischio iniziale dalla criticità che permane dopo l'applicazione delle mitigazioni considerate.